Introduzione alla Crittografia

sulla sicurezza ed altre amenità informatiche

Mirko Zichichi · mirko.zichichi@iota.org

slide in collaborazione con prof. Stefano Ferretti

Seminario "Blockchain e Smart Contract: aspetti giuridici e tecnologici"
Università di Bologna, novembre 2026

Chi sono

Mirko Zichichi, mirkozichichi.me

- **Engineering Team Lead** presso la **IOTA Foundation**: protocolli per registri distribuiti e il linguaggio per smart contract Move
- **Dottorato in Law, Science and Technology** (Joint Doctorate, borsa Marie Skłodowska-Curie), Università di Bologna, Università di Torino e Universidad Politécnica de Madrid (Ontology Engineering Group)
- Tesi: *sistemi decentralizzati per la protezione e la portabilità dei dati personali*

Un informatico tra i giuristi: oggi proviamo a tradurre la crittografia in concetti che usate già, come la firma, la data certa, il sigillo, la busta chiusa.

L’Italia nel mirino: i numeri

507

incidenti gravi in Italia nel 2025: **+42%** sul 2024, il **9,6%** di tutti quelli censiti nel mondo

5.265

incidenti gravi nel mondo nel 2025 (+48,7%): il massimo mai registrato

2.729

eventi gestiti dal CSIRT Italia dell'ACN nel 2025 (+38%), di cui **615** incidenti con impatto confermato

Nel 2026 il ritmo non cala: nei primi nove mesi il CSIRT Italia ha gestito più eventi che in tutto il 2025.

Rapporto Clusit 2026 (17 marzo 2026); Relazione annuale ACN 2025; Operational Summary ACN 2026.

Come leggere i numeri

Clusit conta gli incidenti gravi resi noti da fonti aperte; l’ACN quelli segnalati al CSIRT. Misurano cose diverse.

Gran parte della crescita italiana viene dall’hacktivism (196 incidenti nel 2025): senza, l’aumento sarebbe del 12%, non del 42%.

Dal 2026 gli obblighi di notifica NIS2 fanno crescere anche le segnalazioni.

2 novembre 2026: i frigoriferi dei supermercati

Alle 4 del mattino qualcuno alza da remoto la temperatura di frigoriferi e congelatori in oltre 20 supermercati tra Palermo, Catania, Ragusa e Trapani.

- Colpiti anche punti vendita in Toscana ed Emilia-Romagna; in Europa oltre 100 supermercati in otto Paesi, dopo circa 700 in Francia a ottobre
- Vettore probabile: il software di telegestione degli impianti, esposto su Internet e **non aggiornato**
- Rivendicazione dei gruppi filorussi NoName057(16) e Z-Pentest, **contestata** da esperti e dall'ACN
- L'ACN ha diffuso un bollettino con misure urgenti per la distribuzione alimentare e la filiera del freddo

Per il giurista

Cosa è stato violato? L'**integrità** (parametri modificati) e, di conseguenza, la **disponibilità** (merce da buttare).

Dall'11 settembre 2026 i produttori di dispositivi connessi devono segnalare le vulnerabilità sfruttate e gli incidenti gravi.

¶ art. 14, Reg. (UE) 2024/2847 (Cyber Resilience Act)

Il Post, 3 e 6 novembre 2026; Cybersecurity360 sul bollettino ACN.

Un anno di attacchi, in sei notizie

Per ognuna: quale proprietà della sicurezza è stata violata? Cliccate per scoprirlo.

2 nov 2026 — ✓ confermato

Frigoriferi manomessi nei supermercati, da Palermo a…

Temperature alzate da remoto in oltre 20 punti vendita in Sicilia e in altre regioni, sfruttand…

Violate: **integrità** **disponibilità**

art. 14 Cyber Resilience Act — Il Post, 3/11/2026

8 ott 2026 — ✓ confermato

Attacco al sito della Farnesina

Un attacco DDoS, attribuito dalla stampa al gruppo filorusso NoName057(16), viene…

Violate: **disponibilità**

d.lgs. 138/2024 (NIS2): notifica entro 24 ore

4 feb 2026 — ✓ confermato

Milano-Cortina: attacchi ai siti dei Giochi

Il governo dichiara sventati attacchi di origine russa a sedi diplomatiche e a siti legati alle…

Violate: **disponibilità**

L. 90/2024 sulla cybersicurezza nazionale — T

5 mar 2026 — ✓ confermato

Spyware Paragon: le procure confermano

Le procure di Roma e Napoli trovano tracce di malware sui telefoni di due attivisti e del…

Violate: **riservatezza** **integrità**

art. 615-ter c.p. (accesso abusivo) — Internazi…

feb 2025 — ✓ confermato

La voce clonata del ministro Crosetto

Con una voce ricreata al computer, truffatori ottengono da un imprenditore circa 980.000 …

Violate: **autenticità**

artt. 640 e 494 c.p. (truffa, sostituzione di perso

9 nov 2026 — *solo rivendicato*

File della DIA in vendita sul dark web?

Un venditore offre 302 file attribuiti alla Direzione investigativa antimafia. Per gli…

Violate: **riservatezza**

una rivendicazione non è una prova — AGI, …

Il percorso di oggi

I	Sicurezza informatica	II	Crittografia	III	Crittografia simmetrica
IV	Crittografia asimmetrica	V	Funzioni hash	VI	Puntatori hash e strutture dati
VII	Non ripudio e firma digitale	VIII	Marcatura temporale	IX	Identità decentralizzate

Ogni capo si chiude con una verifica rapida. Le note "Per il giurista", nel margine, collegano la tecnica alle norme.

I

Capo I

Sicurezza informatica

Cosa vogliamo proteggere, da chi, e perché non basta mai

La sicurezza informatica

La protezione delle risorse informatiche dall'accesso, dall'uso, dall'alterazione o dalla distruzione non autorizzati.

Sicurezza fisica

protezione dei dispositivi: allarmi, porte blindate, casseforti, controllo degli accessi alla sala server

Sicurezza logica

protezione delle informazioni con strumenti non fisici: crittografia, firma elettronica, autenticazione, backup

Sicurezza informatica: la terminologia

Riservatezza (*confidentiality*)
impedire la divulgazione non autorizzata dei dati

Integrità (*integrity*)
impedire, o almeno rilevare, le modifiche non autorizzate ai dati

Disponibilità (*availability*)
garantire che dati e servizi siano accessibili quando servono. Minacce: attacchi *Denial of Service* (DoS), ransomware

Autenticazione (*authentication*)
verificare l'identità della controparte e l'origine dei dati: con chi sto comunicando?

Non ripudio (*non-repudiation*)
impedire che la controparte possa negare una sua azione

Correzione rispetto al 2024: "garantire l'autenticità della fonte" non è riservatezza ma autenticazione.

Per il giurista

Le stesse parole sono nel GDPR: il titolare deve assicurare "la riservatezza, l'integrità, la disponibilità e la resilienza dei sistemi e dei servizi di trattamento".

¶ art. 32, par. 1, lett. b), GDPR

Tre aspetti fondamentali

1

Non esistono sistemi sicuri

2

Sicurezza = conoscenza

3

Le componenti di un sistema (in)sicuro: hardware, software, persone

1. Non esistono sistemi sicuri

- Il software può non essere perfetto, e di solito non lo è
- Possono esserci errori di progettazione anche nei protocolli che usiamo tutti i giorni
- Il mito del sistema inviolabile vale quanto quello del caveau impenetrabile o della nave inaffondabile (il Titanic)

Il grado di sicurezza si misura con il tempo necessario per violare il sistema, l'investimento richiesto e la probabilità di successo.

Per il giurista

Il diritto non chiede sicurezza assoluta ma misure **adeguate** al rischio, "tenendo conto dello stato dell'arte e dei costi di attuazione".

¶ art. 32, par. 1, GDPR

Lo stesso approccio basato sul rischio è nella disciplina NIS2 (d.lgs. 138/2024).

1. Sistemi sicuri: la complessità

Più un sistema è complesso, più è insicuro.

- Regola **KISS**: *Keep It Simple, Stupid*
- Eliminare la complessità non necessaria: "quello che non c’è non si rompe"
- Ogni funzione in più è una porta in più da sorvegliare

2. Sicurezza = conoscenza

- Nessun sistema sconosciuto può essere considerato sicuro
- Che cosa implica per il software **open source** e **closed source**, per i sistemi aperti e quelli chiusi?
  - un atto di fiducia verso una **comunità** che può ispezionare il codice, oppure verso un'**azienda**
- L'**educazione degli utenti** è una forma di conoscenza fondamentale: percezione del rischio, pratiche diffuse ma insicure, resistenze ideologiche o semplice abitudine

2. Il principio di Kerckhoffs

> *"Un sistema crittografico deve essere sicuro anche se ogni suo aspetto, tranne la chiave, è di pubblico dominio."*

- È il contrario della "sicurezza tramite segretezza" (*security by obscurity*)
- Lo ribadisce il NIST: "System security should not depend on the secrecy of the implementation or its components"

La serratura può essere pubblica; la chiave no.

A. Kerckhoffs, *La cryptographie militaire*, 1883. NIST SP 800-123, *Guide to General Server Security*, 2008.



Auguste Kerckhoffs (1835–1903)

3. Le componenti di un sistema

Hardware	Software	Humanware le persone

La sicurezza è un processo, non un prodotto:

- serve un apporto continuo di lavoro e di formazione
- un sistema considerato sicuro oggi può non esserlo domani
- i sistemi che non vengono aggiornati diventano fragili e insicuri (pensate ai frigoriferi dei supermercati di inizio novembre)

La componente umana non va mai sottovalutata.

3. Humanware: le password più usate

Nel mondo

1. 123456
2. admin
3. 12345678
4. 123456789
5. 12345
6. password
7. Aa123456
8. 1234567890
9. Pass@123
10. admin123

In Italia

1. admin
2. password
3. 123456
4. Password
5. 12345678
6. 123456789
7. 12345
8. Napoli1926
9. 123stella
10. perlanera

NordPass, *Top 200 most common passwords*, edizione 2025 (violazioni pubbliche analizzate tra settembre 2024 e settembre 2025, 44 Paesi). La slide del 2024 riportava la classifica SplashData 2018: allora in testa c'erano già 123456 e password.

3. Humanware: quanto pesano le password comuni

Su circa 6,5 milioni di credenziali trapelate, quanti utenti usano una password che sta in cima alla classifica?



Quasi un utente su tre si difende con una password che sta in una lista di 10.000 parole: un attaccante la prova in una frazione di secondo.

M. Burnett, *10,000 Top Passwords*, 2011, valori ricalcolati dall'autore. Correzione rispetto al 2024: la slide riportava i numeri della prima versione dell'articolo (91% tra le top 1.000), poi ritrattati, attribuendoli al 2018.

Tu che password usi?

Prova una password

`juventus1897`

La password non lascia questo computer: il calcolo avviene nel browser.

Caratteri usati: ✓ **minuscole** (26) – maiuscole (26) ✓ **cifre** (10) – simboli (33)

Alfabeto e lunghezza	36 simboli possibili, 12 caratteri
Combinazioni	$36^{12} \approx 4{,}74 \times 10^{18}$
Forza bruta, caso peggiore	**15 anni** a 10^{10} tentativi al secondo
Password molto diffuse	✕ **parola della lista + numeri**

✕ **Parola comune + numeri: un attacco a dizionario la prova presto.**

Anche i dati personali aiutano l'attaccante: con nome, data di nascita e una password trapelata da un altro sito, uno studio ha indovinato in 100 tentativi la password di oltre il 73% degli utenti (Wang et al., ACM CCS 2016).

Per il giurista

Entrare in un account con la password altrui è accesso abusivo a un sistema informatico; procurarsi o diffondere le password altrui è reato a sé.

¶ art. 615-ter c.p.

¶ art. 615-quater c.p.

L’attacco a dizionario

Invece di provare tutte le combinazioni, l'attaccante prova prima le password più diffuse.

Account **`avv.bianchi`**

hash della password rubato dal database: `a941a4c4fd…f6c223`

L'attaccante calcola l'hash di ogni parola del dizionario e lo confronta con l'hash rubato.

Tentativi: **20** su 64 parole del dizionario

```
tentativo 13: password1 → 0b14d5… ✗
tentativo 14: iloveyou → e4ad93… ✗
tentativo 15: 1q2w3e4r → 72ab99… ✗
tentativo 16: 000000 → 91b4d1… ✗
tentativo 17: qwerty123 → daaad6… ✗
tentativo 18: zaq12wsx → e3e93b… ✗
tentativo 19: dragon → a9c43b… ✗
tentativo 20: sunshine → a941a4… ✓
✓ trovata: sunshine (tentativo 20)
```

Per il giurista

La NIS2 chiede ai soggetti essenziali e importanti, tra le misure minime, l’uso di soluzioni di **autenticazione a più fattori**.

¶ art. 21, par. 2, lett. j), dir. (UE) 2022/2555; art. 24 d.lgs. 138/2024

Phishing e furto di identità

Spesso la password non serve indovinarla: basta convincere la vittima a consegnarla, con un messaggio che sembra arrivare da qualcuno di fidato.

- Video: una scena di phishing con attacco a dizionario dalla serie *Mr. Robot*: youtube.com/watch?v=JMYEr4Bgey4
- **Febbraio 2025**: truffatori clonano con un software la voce del ministro della Difesa Guido Crosetto e chiamano noti imprenditori chiedendo denaro per un falso riscatto. Uno di loro versa circa **980.000 €** su un conto in Olanda, poi bloccato dalla Procura di Milano

Una voce al telefono non prova l'identità di nessuno: serve un'autenticazione forte (Capo VII).

Per il giurista

Ipotesi di reato indagate nel caso Crosetto: associazione per delinquere finalizzata alla truffa aggravata e sostituzione di persona.

¶ artt. 416, 640, 494 c.p.

Il Post, 11/2/2025; Corriere della Sera, 13/2/2025.

"L’anello più debole"

> *"Security is a chain; it's only as secure as the weakest link."*
> *"La sicurezza è una catena: è sicura solo quanto il suo anello più debole."*

B. Schneier, *Secrets and Lies: Digital Security in a Networked World*, 2000, prefazione.

Per Schneier, le persone sono spesso quell’anello: bellissimi pezzi di matematica resi inutili, scrive, da cattiva programmazione, da un sistema operativo scadente o dalla password scelta male da qualcuno.

Gli esseri umani sono davvero l'anello debole?

> *"All human activity, individually and/or collectively, is variable in the sense that it is adjusted to the conditions. The variability is therefore a strength, indeed a necessity, rather than a liability."*

E. Hollnagel, *The no view of human error* (copia archiviata: il sito originale non è più disponibile).

Il principio ETTO (*Efficiency-Thoroughness Trade-Off*): non si può essere allo stesso tempo massimamente efficienti e massimamente scrupolosi.

- se cresce la pressione sulla **produttività**, cala la scrupolosità
- se cresce la pressione sulla **sicurezza**, cala l'efficienza

Le regole di sicurezza vanno progettate per persone vere, sotto pressione.

Verifica rapida

Un ransomware cifra i server di un ospedale, che non riesce più ad accedere alle cartelle cliniche. Quale proprietà è violata per prima?

- **A** Riservatezza
- **B** Integrità
- **C** Disponibilità ✓ **giusta**

I dati ci sono ma non si possono usare: è la disponibilità. Se gli attaccanti li copiano e minacciano di pubblicarli (doppia estorsione) è violata anche la riservatezza.

Secondo il NIST, cosa rende più sicura una password usata come unico fattore?

- **A** Cambiarla ogni 90 giorni
- **B** Che sia lunga (almeno 15 caratteri) e non compaia nelle liste di password comuni ✓ **giusta**
- **C** Che contenga per forza un simbolo e una maiuscola

La lunghezza e l'assenza dalle liste di password note contano più delle regole di composizione; il cambio periodico obbligatorio è sconsigliato (NIST SP 800-63B-4).

II

Capo II

Crittografia

L’arte di scrivere in modo che solo il destinatario possa leggere

Crittografia

Studia le tecniche per cifrare un messaggio in modo che solo il legittimo destinatario sia in grado di leggerlo. Oggi protegge anche integrità, autenticità e non ripudio.

Due requisiti, in tensione tra loro:

- **Efficienza**: cifrare e decifrare deve essere ragionevolmente veloce per chi è autorizzato
- **Sicurezza**: per chi non è autorizzato deve essere "difficile" (in pratica: troppo costoso o troppo lungo) capire il messaggio cifrato

> *Difficile non vuol dire impossibile: vuol dire che servirebbero più tempo e risorse di quanto valga il segreto.*

Per il giurista

Il GDPR cita la cifratura tra le misure di sicurezza adeguate; la NIS2 chiede politiche sull'uso della crittografia.

¶ art. 32, par. 1, lett. a), GDPR

¶ art. 21, par. 2, lett. h), dir. (UE) 2022/2555 (NIS2)

Crittografia applicata



Il cilindro di Thomas Jefferson, descritto quando era Segretario di Stato (1790–93).
Dischi con alfabeti mescolati: l'ordine dei dischi è la chiave. Forse mai costruito, non risulta che Jefferson l'abbia usato; reinventato da Bazeries (1891), fu usato dall'esercito USA come M-94 dal 1922 alla Seconda guerra mondiale.

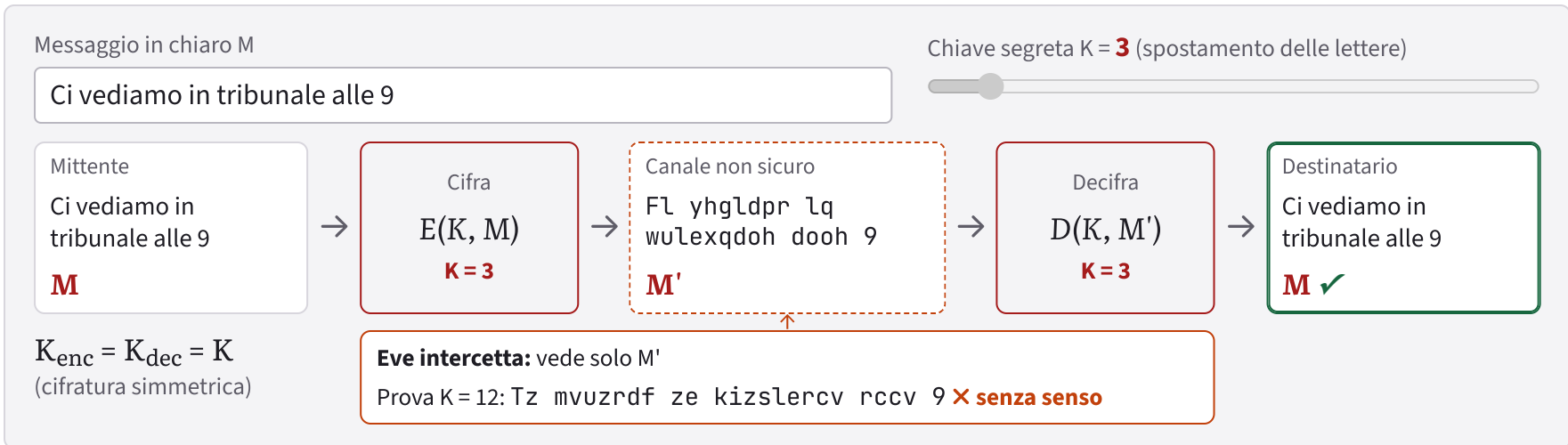


Enigma, usata dalle forze armate tedesche nella Seconda guerra mondiale. Forzata prima dai crittoanalisti polacchi (Rejewski, 1932), poi a Bletchley Park (Turing e altri). Questa è al Museo della Scienza e della Tecnologia di Milano.

Foto: NSA, pubblico dominio; Alessandro Nassiri, CC BY-SA 4.0 (Wikimedia Commons).

Il principio di base

Un algoritmo trasforma il messaggio in chiaro in un messaggio cifrato; un secondo algoritmo, con la chiave giusta, fa il percorso inverso.



Notazione

Simbolo	Significato	In inglese
M	messaggio in chiaro	plaintext
M’	messaggio cifrato	ciphertext
K_{enc}	chiave di cifratura	encryption key
K_{dec}	chiave di decifratura	decryption key
$E(K_{enc}, M) = M'$	funzione di cifratura	encryption
$D(K_{dec}, M') = M$	funzione di decifratura	decryption

Le lettere servono solo a dire con precisione chi usa quale chiave: è il lessico che ritroverete in ogni norma tecnica.

Esempio: il cifrario di Cesare

Ogni lettera viene sostituita da quella che si trova K posizioni più avanti nell'alfabeto. La chiave è il numero K.

Testo in chiaro

Alea iacta est

Chiave K = **3**: ogni lettera avanza di 3 posti

in chiaro	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
cifrato	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C

Testo cifrato **Dohd ldfwd hvw**

Sistemi crittografici: la regola d'oro

$$D(K_{dec}, E(K_{enc}, M)) = M$$

Se cifro un messaggio M con la chiave K_{enc} e decifro il risultato con K_{dec}, devo riottenere esattamente M.

- Se la decifratura non restituisce l'originale, il sistema è inutilizzabile
- Con una chiave sbagliata, invece, il risultato deve essere spazzatura (e non un "quasi originale")

Due famiglie di sistemi crittografici

A chiave segreta

crittografia simmetrica

$$K_{enc} = K_{dec}$$

La stessa chiave serve per chiudere e per aprire: come la chiave di una cassaforte, di cui esistono copie identiche.

A chiave pubblica

crittografia asimmetrica

$$K_{enc} \neq K_{dec}$$

Le chiavi sono diverse: una si può dare a tutti, l'altra resta segreta. Come una cassetta delle lettere: chiunque imbuca, solo il titolare apre.

Verifica rapida

Il cifrario di Cesare con chiave K = 3 trasforma 'CASA' in…

- **A** DBTB
- **B** FDVD ✓ giusta
- **C** ZXPX
- **D** CASA3

> Ogni lettera avanza di 3 posizioni: C→F, A→D, S→V, A→D. Per decifrare si torna indietro di 3: stessa chiave, quindi è un sistema simmetrico.

Capo III

III

Crittografia simmetrica

Una sola chiave, condivisa da mittente e destinatario

Cifratura simmetrica

Mittente e destinatario usano la stessa chiave segreta: chi la possiede legge, chi non la possiede vede solo caratteri senza senso.



Stessa chiave K alle due estremità: è il "segreto condiviso" (*shared secret*).

Il cifrario di Cesare, attaccato

La chiave è un numero da 1 a 25: basta provarle tutte. È l'attacco a forza bruta (*brute force*).

Testo cifrato intercettato (chiave sconosciuta)

```
Dwwdffr doo'doed
```

Proviamo tutte le 25 chiavi. Quale riga si legge?

K = 1 `Cvvceeq cnn'cndc`	K = 2 `Buubddp bmm'bmcb`	K = 3 **`Attacco all'alba`**	K = 4 `Zsszbbn zkk'zkaz`
K = 5 `Yrryaam yjj'yjzy`	K = 6 `Xqqxzzl xii'xiyx`	K = 7 `Wppwyyk whh'whxw`	K = 8 `Voovxxj vgg'vgwv`
K = 9 `Unnuwwi uff'ufvu`	K = 10 `Tmmtvvh tee'teut`	K = 11 `Sllsuug sdd'sdts`	K = 12 `Rkkrttf rcc'rcsr`
K = 13 `Qjjqsse qbb'qbrq`	K = 14 `Piiprrd paa'paqp`	K = 15 `Ohhoqqc ozz'ozpo`	K = 16 `Nggnppb nyy'nyon`
K = 17 `Mffmooa mxx'mxnm`	K = 18 `Leelnnz lww'lwml`	K = 19 `Kddkmmy kvv'kvlk`	K = 20 `Jccjllx juu'jukj`
K = 21 `Ibbikkw itt'itji`	K = 22 `Haahjjv hss'hsih`	K = 23 `Gzzgiiu grr'grhg`	K = 24 `Fyyfhht fqq'fqgf`
K = 25 `Exxeggs epp'epfe`			

✓ Trovata: K = 3, al massimo 25 tentativi.

Una chiave che cambia

Idea: cambiare la chiave secondo una sequenza concordata, così lo stesso messaggio produce ogni volta un cifrato diverso.

Messaggio

`Hello`

Stesso messaggio, chiave diversa ogni volta: **testi cifrati diversi**. Chi intercetta non capisce nemmeno che il messaggio si ripete.

Cifratura n. 1
spostamento +3
`Hello` → **`Khoor`**

Cifratura n. 2
spostamento −1
`Hello` → **`Gdkkn`**

Cifratura n. 3
spostamento +2
`Hello` → **`Jgnnq`**

Cifratura n. 4
spostamento +6
`Hello` → **`Nkrru`**

Vigenère: la chiave cambia a ogni lettera

Parola chiave `LEX` — L = 11, E = 4, X = 23 (A = 0 … Z = 25)

Messaggio	H	e	l	l	o
Lettera della chiave	L	E	X	L	E
Spostamento	11	4	23	11	4
Risultato	**S**	**i**	**i**	**w**	**s**

La stessa lettera del messaggio può diventare lettere diverse: le frequenze delle lettere non si riconoscono più.

DES: Data Encryption Standard

- Progettato da **IBM**, adottato come standard federale USA nel **1977**
- Chiave di **56 bit**; il messaggio è diviso in blocchi da 64 bit, cifrati uno per uno
- Chiavi possibili: $2^{56} \approx 7{,}2 \times 10^{16}$
- Sembrano tante, ma nel **1998** la macchina *Deep Crack* della EFF trovò una chiave in **56 ore**, nel 1999 in 22 ore. Oggi hardware dedicato prova **tutte** le chiavi in circa un giorno; una sola scheda grafica di fascia alta in circa sei giorni
- La variante **Triplo DES** (tre passaggi, circa 112 bit di sicurezza) è stata a lungo il rimedio: dal 1° gennaio 2024 il NIST non la ammette più per cifrare

Morale: una chiave è sicura finché provarle tutte costa più di quanto valga il segreto. I computer diventano più veloci: le chiavi devono allungarsi.

EFF (1998, 1999); crack.sh (48 FPGA, ~26 ore); NIST SP 800-131A Rev. 2.

AES: Advanced Encryption Standard

- Adottato come standard nel **2001** (NIST FIPS 197), sostituisce DES
- Il messaggio è diviso in blocchi da **128 bit**, cifrati uno per uno
- Chiavi da **128, 192 o 256 bit**
- Chiavi da 128 bit possibili: $2^{128} \approx 3{,}4 \times 10^{38}$: esplorarle tutte è oggi impraticabile
- Resta adeguato anche in vista dei computer quantistici: il NIST non prevede di sostituirlo

È l'algoritmo che protegge, ogni giorno, il Wi-Fi, i dischi cifrati dei portatili, WhatsApp e le connessioni HTTPS.

> ***Per il giurista***
>
> Cifrare conviene anche giuridicamente: se i dati sottratti erano cifrati, il titolare non deve comunicare la violazione agli interessati.
>
> ¶ art. 34, par. 3, lett. a), GDPR
>
> (Resta l'obbligo di notificarla al Garante, se ci sono rischi: art. 33.)

Quanto tempo serve per esplorare tutte le chiavi?

Password | Chiavi

età dell'universo ≈ $1{,}38 \times 10^{10}$ anni

Alfabeto: solo minuscole (26)

Lunghezza: **8** caratteri

Chi attacca: tentativi al secondo: un computer: 1 miliardo al secondo

$26^8 \approx 2{,}09 \times 10^{11}$ combinazioni → nel caso peggiore **3,5 minuti**

Password	Combinazioni	un computer (10^9/s)	un grande impianto dedicato (10^{13}/s)
8 caratteri, minuscole	$26^8 \approx 2{,}09 \times 10^{11}$	3,5 minuti	istantaneo
10 caratteri, minuscole	$26^{10} \approx 1{,}41 \times 10^{14}$	1,6 giorni	14 secondi
12 caratteri, minuscole	$26^{12} \approx 9{,}54 \times 10^{16}$	3 anni	2,7 ore
12 caratteri, lettere e cifre	$62^{12} \approx 3{,}23 \times 10^{21}$	102.234 anni	10 anni
15 caratteri, lettere e cifre	$62^{15} \approx 7{,}69 \times 10^{26}$	$2{,}44 \times 10^{10}$ anni	$2{,}44 \times 10^{6}$ anni

Crittografia simmetrica: pro e contro

A favore: è molto **efficiente**, anche su grandi quantità di dati.

Punti deboli:

- **Distribuzione delle chiavi**: serve un modo sicuro per accordarsi sulla chiave
- **Scalabilità**: serve una chiave diversa per ogni coppia di interlocutori
- **Garanzie limitate**: protegge la riservatezza; l'autenticità è limitata alle due parti e **non c'è non ripudio** (la chiave ce l'hanno entrambi)

Per il giurista

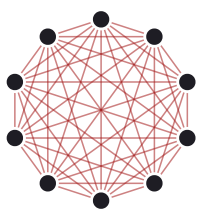
Se la stessa chiave è nelle mani di entrambe le parti, ciascuna può aver prodotto il messaggio: davanti a un terzo nessuna delle due può provare che l'ha scritto l'altra.

Serve qualcosa che solo una parte possiede: la chiave privata (Capo IV).

Quante chiavi servono?

Con la crittografia simmetrica serve una chiave segreta per ogni coppia di persone: il numero cresce con il quadrato di n.

Persone che vogliono scriversi in privato, a due a due: **10**

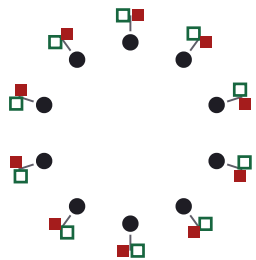


Cifratura simmetrica

45

chiavi segrete condivise

una per ogni coppia: n(n − 1)/2



Cifratura asimmetrica

10

coppie di chiavi

una per persona: 10 pubbliche + 10 private

pubblica privata

Il numero di chiavi simmetriche cresce con il quadrato di n (non esponenzialmente): il doppio delle persone, circa il quadruplo delle chiavi.

Con n = 1.000: **499.500** chiavi segrete contro **1.000** coppie di chiavi.

IV

Capo IV

Crittografia asimmetrica

Una chiave per tutti, una chiave solo per me

Crittografia a chiave pubblica

Ognuno ha una coppia di chiavi legate tra loro: una pubblica e una privata.

Chiave pubblica

resa disponibile a chiunque, come un indirizzo o un numero di conto

Chiave privata

custodita gelosamente dal titolare e mai comunicata a nessuno

Ciò che una chiave chiude, solo l'altra lo apre. E dalla chiave pubblica non si può ricavare quella privata.

Per il giurista

È la definizione stessa di firma digitale nel diritto italiano:

"un sistema di chiavi crittografiche, una pubblica e una privata, correlate tra loro" che consente al titolare (con la privata) e a un terzo (con la pubblica) di rendere manifesta e di verificare provenienza e integrità del documento.

¶ art. 1, c. 1, lett. s), CAD (d.lgs. 82/2005)

Alice scrive a Bob, in segreto

Alice cifra con la chiave pubblica di Bob; solo Bob, con la sua chiave privata, può decifrare.

Alice scrive a Bob

Il cliente accetta la transazione a 50.000 €

Alice cifra con la chiave pubblica di Bob

Messaggio cifrato, lo vede chiunque sulla rete (256 byte):

`8bc34124df16f37d3689fb1d39c8 1226e6467952…80e22ff8`

Bob, il destinatario

pubblica `e41a 94af eb97 a54a` può conoscerla chiunque

privata la conosce solo Bob

Bob decifra con la sua chiave privata

✓ **«Il cliente accetta la transazione a 50.000 €»**

Eve intercetta il messaggio

privata di Eve è un'altra chiave, non quella di Bob

Eve prova con la sua chiave privata

✕ **impossibile decifrare**

Cosa si ottiene con le due chiavi

Cifro con la chiave pubblica del destinatario

- **Riservatezza**: soggetti non autorizzati non possono leggere il dato; solo il destinatario ha la chiave privata

Firmo con la mia chiave privata

- **Autenticità**: si verifica da chi proviene il messaggio
- **Integrità**: ci si accorge se è stato alterato durante la trasmissione, per errore o di proposito
- **Non ripudio**: il mittente non può negare in seguito di averlo inviato

La colonna di destra è la firma digitale: la vediamo nel Capo VII.

RSA (Rivest–Shamir–Adleman, 1977)

La sua sicurezza si basa, in parte, su un fatto pratico: moltiplicare due numeri primi grandi è facile, risalire ai fattori dal prodotto è difficilissimo.

Moltiplicare è facile

p 7919 × q 104.729

`n = 829.348.951` 9 cifre, calcolato all'istante

Fattorizzare è difficile

Chi conosce solo n prova a dividerlo per 2, 3, 5, 7, 9, … finché trova un divisore.

tentativi **3960**

✓ n = 7919 × 104.729, trovato dopo 3960 tentativi

Una chiave RSA-2048 ha un modulo di **617 cifre decimali**; qui n ne ha 9.

Per il giurista

Settembre 2026: due record in 16 giorni.

RSA-260 (862 bit) fattorizzato con GPU in circa 13,5 anni-GPU (≈ 400.000 $); poi RSA-896, con l'aiuto di agenti di intelligenza artificiale.

RSA-2048 (617 cifre) resta fuori portata; ma le chiavi da 1024 bit non vanno più considerate sicure.

E. Lu, Cognition, 9.9.2026; S. Weis, 19.9.2026

E il computer quantistico?

Un computer quantistico abbastanza grande, con l'algoritmo di Shor (1994), romperebbe RSA e le curve ellittiche. Oggi non esiste, ma ci si prepara.

- **13 agosto 2024**: il NIST pubblica i primi standard "post-quantistici" (FIPS 203, 204, 205: ML-KEM, ML-DSA, SLH-DSA); a marzo 2025 sceglie HQC come riserva
- **Giugno 2025**: tabella di marcia comune UE: piani nazionali entro il 2026, sistemi ad alto rischio migrati entro il 2030, gli altri per quanto possibile entro il 2035
- **27 ottobre 2026**: il NIST fissa il calendario definitivo (IR 8547): RSA e curve ellittiche **deprecati dopo il 2030, vietati dopo il 2035**

Per il giurista

"Raccogli ora, decifra dopo" (*harvest now, decrypt later*): chi intercetta oggi comunicazioni cifrate può conservarle e leggerle tra dieci o quindici anni.

Per atti coperti da segreto professionale, dati sanitari o giudiziari, la riservatezza deve durare più a lungo della crittografia che la protegge. Le firme, invece, non corrono questo rischio.

La tabella UE è *soft law* (Racc. (UE) 2024/1101): diventa vincolante attraverso lo "stato dell'arte" (art. 32 GDPR; art. 21 NIS2).

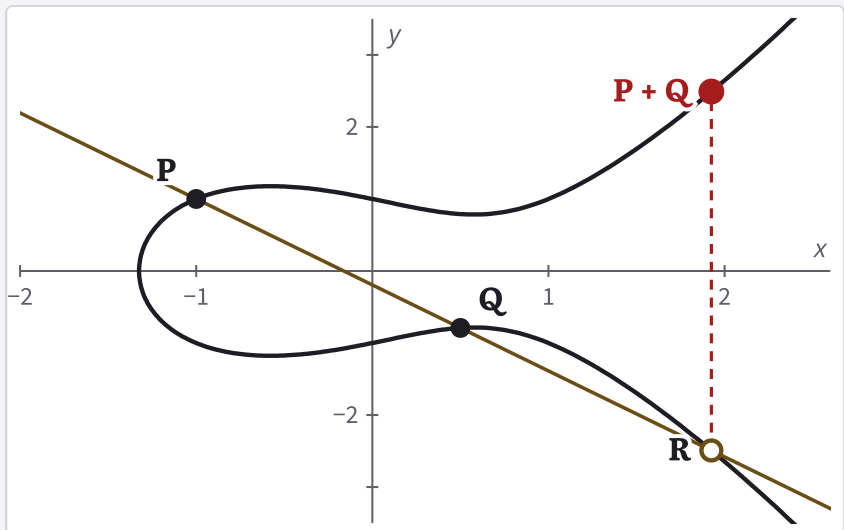
ECDSA: firme su curve ellittiche

Elliptic Curve Digital Signature Algorithm: la firma digitale basata sulla geometria delle curve ellittiche.

- Stessa sicurezza di RSA con **chiavi molto più corte**: una chiave ECC da 256 bit vale circa una chiave RSA da 3072 bit (NIST SP 800-57)
- Usata da **Bitcoin** ed **Ethereum** per firmare le transazioni (curva secp256k1): chi controlla la chiave privata controlla i fondi
- Variante moderna: **EdDSA / Ed25519** (RFC 8032), approvata dal NIST nel 2023
- Anche le curve ellittiche cadrebbero con un computer quantistico: il sostituto previsto è ML-DSA (FIPS 204)

La geometria delle curve ellittiche

La chiave privata è un numero n; la chiave pubblica è un punto fisso "sommato" a sé stesso n volte.



$y^2 = x^3 - x + 1$

$P = (-1; 1) \cdot Q \approx (0{,}5; -0{,}79)$

1. Traccia la retta per P e Q

la retta taglia la curva in un terzo punto R

2. Trova il terzo punto di intersezione

$R \approx (1{,}92; -2{,}49)$

3. Rifletti rispetto all'asse x: è P + Q

$P + Q \approx (1{,}92; 2{,}49)$

Sui numeri reali per farla vedere; in crittografia si usa la stessa regola su un insieme finito di punti.

Verifica rapida

Alice vuole mandare a Bob un documento riservato. Con quale chiave lo cifra?

- **A** La chiave privata di Alice
- **B** La chiave pubblica di Bob ✓ **giusta**
- **C** La chiave privata di Bob

Con la chiave pubblica di Bob: solo la chiave privata di Bob, che nessun altro possiede, potrà decifrarlo.

Perché la crittografia asimmetrica risolve il problema della distribuzione delle chiavi?

- **A** Perché le chiavi sono più lunghe
- **B** Perché la chiave pubblica si può diffondere senza rischi ✓ **giusta**
- **C** Perché non usa chiavi

La chiave pubblica può viaggiare in chiaro: non serve un canale sicuro per accordarsi prima su un segreto comune.

V

Capo V

Funzioni hash

L’impronta digitale di un documento

Funzione hash

Una funzione che trasforma dati di qualsiasi dimensione in un valore di dimensione fissa, chiamato digest o impronta.



Testo A

La volpe

`01a1d88cb53073a8315394c983e96499935452407 24a4f356bbff4f56c3109a2`

Testo B

La volpe rossa corre sul ghiaccio

`2504060688fae70ced883c5b1749e6597a13236c67198e304a1daf8633fbb409`

Bit diversi: **120** su 256 (47%)

Funzioni hash crittografiche

Una classe speciale di funzioni hash, progettate per resistere a chi cerca di ingannarle. Da qui in poi "hash" vuol dire sempre "hash crittografico".

Dove si usano:

- **verifica dell'integrità** di messaggi e file
- **firma digitale** (si firma l'impronta, non il documento intero)
- **verifica delle password** (il sistema conserva l'impronta, non la password)
- **proof-of-work** nelle blockchain

> ***Per il giurista***
>
> Le regole tecniche italiane definiscono la funzione di hash come quella che genera un'**impronta** "in modo tale che risulti di fatto impossibile, a partire da questa, ricostruire l'evidenza informatica originaria e generare impronte uguali a partire da evidenze informatiche differenti".
>
> ¶ art. 1, lett. g) e h), d.P.C.M. 22/2/2013

Le proprietà di una funzione hash crittografica

$$m \rightarrow H \rightarrow H(m)$$

- **Efficiente**: calcolare H(m) è veloce, anche per file grandi
- Proprietà di sicurezza:
  1. **Resistenza alle collisioni** (*collision resistance*): è impraticabile trovare due input con la stessa impronta
  2. **Occultamento** (*hiding*): dall'impronta non si risale all'input, se l'input contiene un segreto casuale
  3. **Adatta ai puzzle** (*puzzle-friendly*): non ci sono scorciatoie per trovare un input con un'impronta di forma data

Le vediamo una alla volta, ciascuna con la sua applicazione.

1) Resistenza alle collisioni

Deve essere computazionalmente impraticabile trovare x e y, con $x \neq y$, tali che $H(x) = H(y)$.

Ma le collisioni esistono! Principio dei cassetti (*pigeonhole*): se metto n oggetti in m cassetti, con n > m, almeno un cassetto contiene più di un oggetto.

Gli input possibili sono infiniti, le impronte da 256 bit "solo" 2^{256}: quindi esistono input diversi con la stessa impronta. Il punto è che **nessuno sa trovarli**.

Quante sono 2^{256} impronte?

Circa $1{,}16 \times 10^{77}$: lo stesso ordine di grandezza del numero di atomi stimato nell'universo osservabile (10^{78}–10^{82}).

1) Come si trova una collisione?

- Con un'impronta da 256 bit ci sono 2^{256} valori possibili
- Metodo generico: calcolare l'impronta di tanti input a caso e aspettare che due coincidano
- Con 2^{130} input scelti a caso, la probabilità che due collidano supera il **99,8%** (paradosso del compleanno)
- Funziona con qualunque funzione H…
- …ma richiede troppo tempo per avere importanza: anche calcolando 10^{18} impronte al secondo servirebbero circa 4×10^{13} anni, migliaia di volte l'età dell'universo

Fonte: A. Narayanan et al., *Bitcoin and Cryptocurrency Technologies*, Princeton University Press, 2016, cap. 1.

1) Applicazione: identificare un file

Se $H(x) = H(y)$, possiamo assumere che $x = y$.

- Per riconoscere un file basta ricordare la sua impronta: 256 bit, pochi byte
- Chi riceve un file può controllare che sia proprio quello atteso, confrontando le impronte

Per il giurista

Nel sequestro e nella copia di dati informatici la legge chiede misure tecniche che assicurino la conservazione dei dati originali e ne impediscano l'alterazione.

Calcolare l'impronta dell'originale e della copia forense, e verbalizzarla, è il modo in cui si dimostra che la copia è identica.

¶ artt. 247, c. 1-bis, 254-bis e 260, c. 2, c.p.p. (L. 48/2008, ratifica della Convenzione di Budapest)

La legge non nomina l'hash: indica il risultato da garantire.

1) Applicazione: integrità dei dati (chi riceve ricalcola l'impronta)

Bob invia il documento e la sua impronta

Contratto di locazione: canone mensile 800 €

Impronta inviata `260451102fba4fa5dea1135b…e3d16c16fd69b4`

Alice riceve la copia intatta ✓ integro

Contratto di locazione: canone mensile 800 €

Impronta ricalcolata `260451102fba4fa5dea1135b…e3d16c16fd69b4`

Alice riceve la copia modificata dall'intruso ✕ alterato

Contratto di locazione: canone mensile 900 €

Impronta ricalcolata `7c377fd091a2971f076f2b86…1f6442ea06790b`

Se l'intruso può cambiare anche l'impronta, il solo hash non basta: serve la firma digitale (Capo VII).

Per il giurista

Attenzione: l'hash **rivela** l'alterazione, non la **impedisce**.

E se l'intruso sostituisce anche l'impronta allegata, il confronto torna. Per questo l'impronta va protetta con una firma (Capo VII) o pubblicata altrove (Capo VI).

2) Occultamento (*hiding*)

Data l'impronta H(x), deve essere impraticabile risalire a x (resistenza alla preimmagine). Ma attenzione a quanti sono i possibili x.

Testo A

moat

`edf1eb932299d2c1e3c973f57e454fbdf5aceeed86bae113708c69d9adc737f4`

Testo B

maot

`b075b42502 5fab0e0d45a491b5ddb4d42b6c 872f5a2c5f69e32996f9 e90b8f0b`

Bit diversi: **141** su 256 (55%)

Due parole che differiscono solo per l'ordine di due lettere danno impronte che non hanno nulla in comune. E la lunghezza è sempre la stessa: 256 bit per SHA-256.

2) Quando l'occultamento fallisce

Se gli input possibili sono pochi, basta calcolare l'impronta di tutti e confrontarla.

Ho scelto **testa** o **croce** e tengo la scelta nascosta: pubblico solo l'impronta SHA-256.

Senza segreto

Impronta pubblicata H(scelta) `16311b8e4f9c…3d60a0`

H(«testa»)	`4417a30dc8c6…8fbedd`	≠ diversa
H(«croce»)	`16311b8e4f9c…3d60a0`	= **uguale**

✕ Scelta scoperta, era «croce»: con solo due possibilità, l'impronta non nasconde nulla.

Con un segreto casuale (nonce)

Impronta pubblicata H(nonce ‖ scelta)

`ec90d6c48ca7…c400c9`

nonce segreto di 128 bit

H(«testa»)	`4417a30dc8c6…8fbedd`	≠ diversa
H(«croce»)	`16311b8e4f9c…3d60a0`	≠ diversa

✓ Nessuna corrisponde: senza il nonce l'impronta non rivela la scelta.

2) L'occultamento funziona solo se...

- l'insieme dei possibili valori di x è **molto grande**
- nessun valore di x è **più probabile** degli altri
- nessun valore di x è **più interessante** degli altri

Rimedio: aggiungere a x un segreto casuale r (*nonce*) e pubblicare $H(r \| x)$. Senza r, l'impronta non dice nulla, anche se x può assumere solo due valori.

2) Applicazione: impegno (*commitment*)

Sigillare oggi un valore in una busta, aprirla solo più tardi.

Chi offre, in privato

Offerta: 125.000 €

Segreto casuale (nonce, 128 bit): `7c1e9a4b3f…7d3a52`: lo conosce solo chi offre

Busta chiusa: si pubblica solo l'impronta H(nonce ‖ offerta)

`845797782898d6f91ec55e306b4c2b17a59b8bf0047e325551ec4f10b81be845`

Si rivelano l'offerta «**Offerta: 125.000 €**» e il nonce `7c1e9a4b3f…7d3a52`

Impronta ricalcolata

`845797782898d6f91ec55e306b4c2b17a59b8bf0047e325551ec4f10b81be845`

✓ **L'impronta corrisponde: è proprio l'offerta sigillata.**

Per il giurista

È la versione digitale dell'offerta in busta chiusa:

- finché la busta è chiusa, nessuno conosce l'offerta (occultamento);
- una volta pubblicata l'impronta, l'offerente non può più cambiarla (resistenza alle collisioni).

3) Adatta ai puzzle (*puzzle-friendly*)

Se una parte dell'input è scelta a caso, non esiste un modo più furbo di "provare a caso" per ottenere un'impronta con una forma desiderata.

- Fisso un dato k (scelto in modo imprevedibile) e cerco un x tale che H(k ‖ x) abbia una certa forma (per esempio, che inizi con molti zeri)
- Puzzle-friendly vuol dire: l'unica strategia è provare un x dopo l'altro, e ogni tentativo è come lanciare una moneta

Correzione rispetto al 2024: la slide originale descriveva come "puzzle-friendly" una proprietà che è in realtà l'occultamento (data H(r ‖ x), non si risale a x).

3) Applicazione: il puzzle di ricerca

Dato un puzzle k e un insieme bersaglio Y, trova un x tale che $H(k \| x) \in Y$. Più Y è piccolo, più il puzzle è difficile.

Dati del blocco k

Blocco 1: Alice paga Bob 10

Difficoltà d

4 zeri

Trova un numero x tale che l'impronta H(k + x) inizi con **0000**. Si può solo tirare a indovinare: in media servono 16^4 = **65.536** tentativi.

tentativi **288.160**

H(k + 288159)

0000**67296e9abe8e46316df031dbb74b4c7e6ef0a68a767ea98d5f454387b5b5**

✓ **Trovato: x = 288159, dopo 288.160 tentativi.** Verificarlo invece richiede un solo calcolo.

Funzioni hash: schemi esistenti

Funzione	Impronta	Stato
MD5 (1992)	128 bit	**rotta**: una collisione costa circa 2^{18} calcoli, una frazione di secondo su un normale computer (2013)
SHA-1 (1995)	160 bit	**rotta**: prima collisione reale nel 2017 (SHAttered), collisioni a prefisso scelto nel 2020; il NIST la ritira entro il 2030
SHA-2 (SHA-256/384/512)	256–512 bit	**raccomandata**
SHA-3 (Keccak, 2015)	224–512 bit	**raccomandata**

La slide del 2024 diceva che per SHA-1 c'erano solo "attacchi teorici, non ancora collisioni": non è più vero dal 2017.

Per il giurista

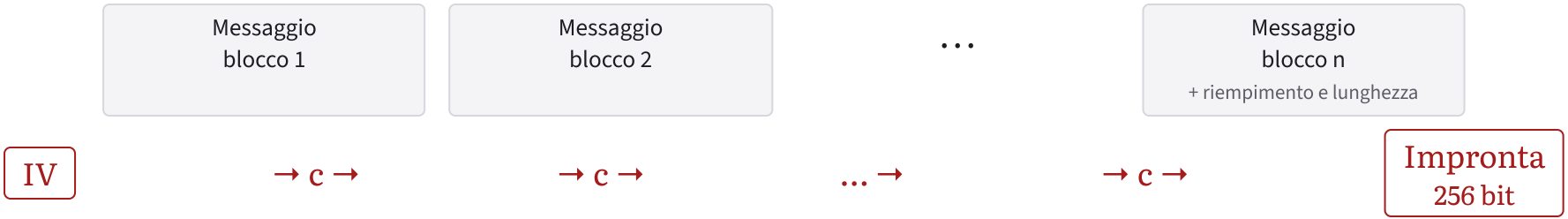
Per l'ACN, MD5 e SHA-1 "sono obsoleti e non vengono consigliati per alcuna applicazione".

Le password non si conservano con un hash veloce ma con funzioni lente e un "sale" casuale di almeno 128 bit per utente: Argon2id, scrypt o PBKDF2 (bcrypt è sconsigliato).

¶ ACN, Linee guida Funzioni di hash, v1.1, 2026

¶ ACN e Garante, Linee guida Conservazione delle password (Garante, provv. n. 594 del 7/12/2023)

SHA-256: come è fatta dentro



- Il messaggio è diviso in blocchi da **512 bit** (l'ultimo completato con un riempimento che include la lunghezza)
- Uno stato di **256 bit** parte da un valore fisso (*IV*, vettore di inizializzazione) e attraversa la **funzione di compressione c** blocco dopo blocco
- Se c resiste alle collisioni, anche SHA-256 resiste (teorema di Merkle–Damgård). Per SHA-256 la resistenza di c è un'ipotesi, finora mai smentita

Esempio: SHA-256 dal vivo

Cambiamo una sola lettera, la J maiuscola di "Jack", nella seconda riga.

Testo A

```
All work and no play makes Jack a dull boy
All work and no play makes Jack a dull boy
All work and no play makes Jack a dull boy
```

`f80f3a6b5ae6d5f33fce632cfb867e98843cbd6f7976feebe7e4cf29b4a37659`

Testo B

```
All work and no play makes Jack a dull boy
All work and no play makes jack a dull boy
All work and no play makes Jack a dull boy
```

`65e0375fdaf60711368914051a53c8dceb74af8c6c7bc251200dccf4eb51e264`

Bit diversi: **126** su 256 (49%)

☐ aggiungi "a capo" finale (come fa `echo`)

Verifica rapida

Un perito calcola l'impronta SHA-256 di un hard disk sequestrato e, mesi dopo, quella della copia: coincidono. Cosa può concludere?

- **A** Che la copia è identica all'originale — ✓ **giusta**
- **B** Che nessuno ha mai letto i dati
- **C** Niente: le collisioni esistono

> Le collisioni esistono in teoria, ma trovarne una è impraticabile: impronte uguali significano, in pratica, dati identici. L'impronta non dice invece nulla su chi ha letto i dati.

Perché non basta pubblicare H(«sì») per tenere segreto un voto sì/no?

- **A** Perché SHA-256 è lento
- **B** Perché chiunque può calcolare H(«sì») e H(«no») e confrontare — ✓ **giusta**
- **C** Perché l'impronta è troppo lunga

> Con due soli input possibili l'occultamento fallisce: serve un segreto casuale (nonce) da aggiungere al voto.

Capo VI

VI

Puntatori hash e strutture dati

Come incatenare i dati in modo che ogni manomissione si veda

Puntatore hash (*hash pointer*)

Un riferimento che dice dove si trova un dato e, insieme, qual era la sua impronta.

1. Puntatore a dove è conservata l'informazione

serve per **trovarla**

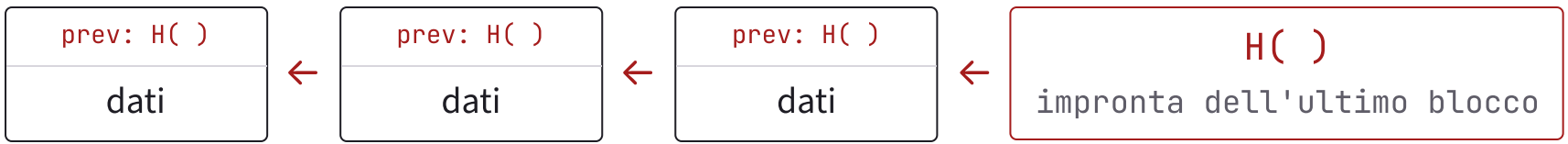
2. Impronta (hash) di quell'informazione

serve per **verificare** che non sia cambiata

Analogia: una nota a piè di pagina che cita un documento *e* ne riporta l'impronta. Se qualcuno sostituisce il documento citato, la citazione non torna più.

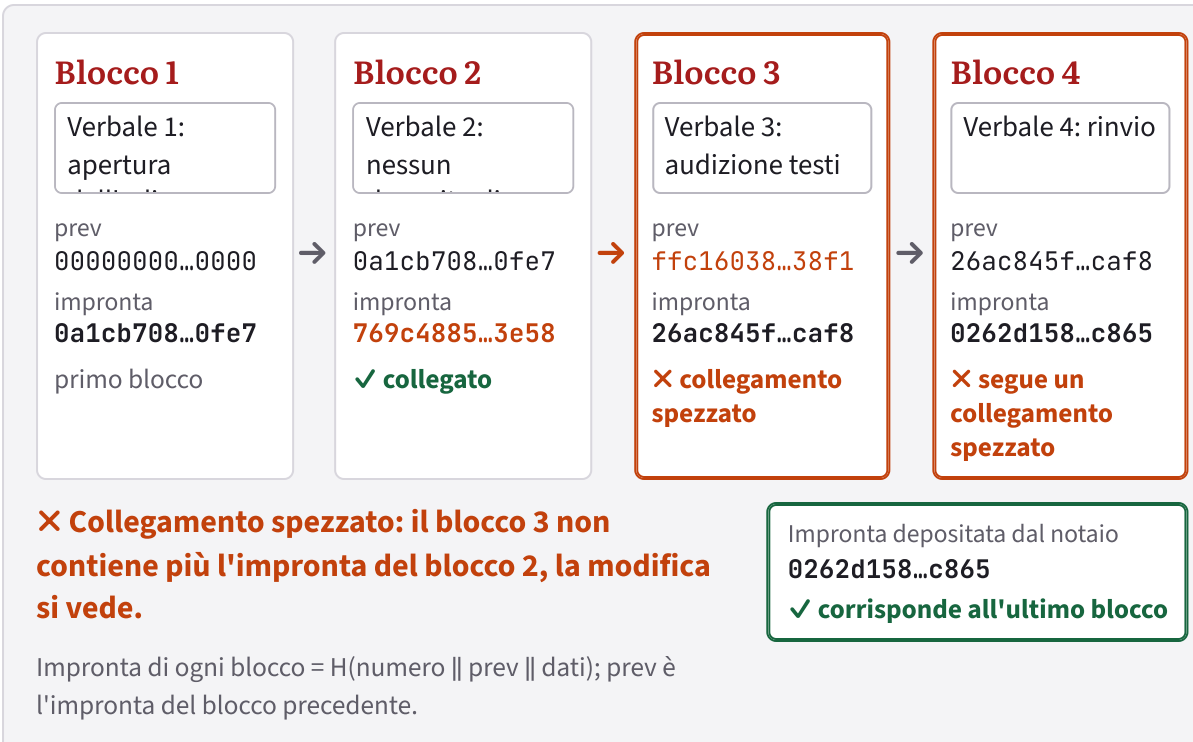
L’idea chiave: strutture dati fatte di puntatori hash

Ogni blocco contiene i propri dati e il puntatore hash al blocco precedente. Basta conservare l'impronta dell'ultimo blocco.



È la struttura che, nel 2008, Bitcoin ha reso famosa con il nome di **blockchain**: una catena di blocchi.

Rilevare la manomissione (*tamper-evident log*)



Per il giurista

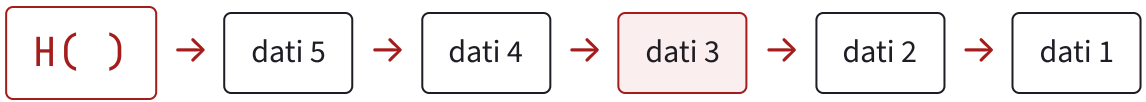
Come un registro con le pagine numerate e collegate: si può ancora strappare o riscrivere una pagina, ma non senza che si veda.

Il registro di protocollo informatico della PA conserva, per i documenti trasmessi per via telematica, proprio l'impronta del documento.

¶ art. 53 d.P.R. 445/2000

Dimostrare che un elemento è nella catena

Dati n elementi in una catena di puntatori hash, quanto costa dimostrare che un elemento ne fa parte?



Bisogna ripercorrere la catena: costo proporzionale a n, cioè O(n)

Con un milione di elementi, nel caso peggiore, un milione di passaggi. Si può fare di meglio?

Albero binario di puntatori hash: l’albero di Merkle

Si fa l'impronta dei dati a coppie, poi delle coppie di impronte, e così via fino a una sola impronta: la radice (*root*).

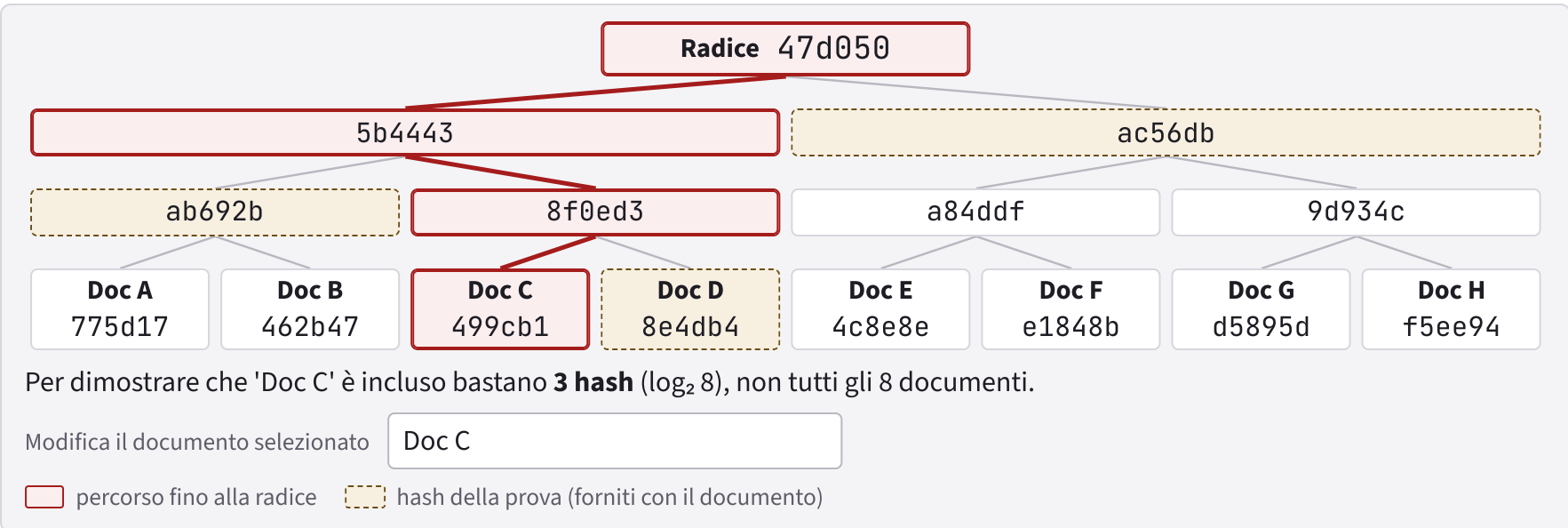
- In fondo (foglie): l’impronta di ogni dato, per esempio di ogni transazione
- A ogni livello: l’impronta delle due impronte sottostanti
- In cima: la **radice**, che "riassume" tutti i dati

Quanti livelli servono per n dati? Circa $\log_2 n$: 8 dati → 3 livelli; un milione di dati → 20 livelli.

Ralph Merkle, brevetto USA 4.309.569 (domanda del 1979, concesso nel 1982).

Dimostrare l'appartenenza in un albero di Merkle

Bastano le impronte "sorelle" lungo il percorso fino alla radice: O(log n) elementi invece di n.



Hash camaleontico (*chameleon hashing*)

Una funzione hash con una "botola": chi possiede una chiave segreta può trovare collisioni, tutti gli altri no.

- Usa una coppia di chiavi: **pubblica** e **privata**
- Con la **chiave pubblica** chiunque calcola e verifica l'impronta; senza la chiave privata trovare collisioni è computazionalmente impraticabile
- Con la **chiave privata** (la "botola", *trapdoor*) si può trovare un nuovo input che dà **la stessa impronta**
- Così si può sostituire un contenuto senza rompere i puntatori hash che lo citano

H. Krawczyk, T. Rabin, *Chameleon Signatures*, NDSS 2000. Applicato alle blockchain "modificabili" (*redactable blockchain*) da G. Ateniese et al., IEEE EuroS&P 2017.

Per il giurista

Un registro immutabile si scontra con il diritto alla cancellazione (art. 17 GDPR).

L'hash camaleontico è una delle risposte tecniche, ma chi ha la "botola" diventa un punto di fiducia.

Per l'EDPB la cancellazione sulla catena può essere "tecnicamente impraticabile": non è consigliabile registrarvi dati personali, né in chiaro, né cifrati, né come hash.

¶ EDPB, Linee guida 02/2025 sulla blockchain, v2.0 del 7 luglio 2026, §§ 103–104

Verifica rapida

In una catena di puntatori hash qualcuno modifica il blocco 2 di 4. Cosa succede?

- A Nulla di visibile
- **B** Il collegamento del blocco 3 non torna più ✓ **giusta**
- C Si cancellano tutti i blocchi

Il blocco 3 conserva l'impronta del blocco 2 originale: non corrisponde più. Per nascondere la modifica bisognerebbe ricalcolare tutta la catena fino all'impronta conservata altrove.

Un albero di Merkle contiene 1.024 documenti. Quante impronte servono per dimostrare che un documento è incluso?

- A 1.024
- B 512
- **C** 10 ✓ **giusta**

$\log_2 1.024 = 10$: una impronta sorella per ogni livello dell'albero.

Capo VII

VII Non ripudio e firma digitale

Dalla matematica delle chiavi al valore giuridico della firma

Non ripudio nella sicurezza digitale

Un servizio che fornisce la prova dell'integrità e dell'origine dei dati, verificabile anche da un terzo (per esempio un giudice): chi ha firmato non può negare di averlo fatto.

Due ingredienti:

1. **Integrità**: i dati sono esattamente quelli firmati
2. **Autenticazione dell'origine**: i dati provengono davvero da chi dice di averli prodotti

Nel mondo cartaceo: la sottoscrizione autografa, e il disconoscimento della scrittura privata quando qualcuno nega di averla firmata.

L’integrità

- L’**impronta** (hash) dei dati permette di **accorgersi**, con probabilità altissima, di qualunque alterazione
- L’integrità va **verificata dal destinatario**: è lui che ricalcola l’impronta e la confronta

Correzione rispetto al 2024: l'hash non rende "improbabile" l'alterazione, la rende **rilevabile**. Chiunque può modificare un file; l'impronta dice se è successo.

La verifica dell'origine

Il metodo più comune per verificare l'origine dei dati è la firma digitale, accompagnata da un certificato digitale.

- **Firma digitale**: prova che il documento è stato firmato con una certa chiave privata
- **Certificato digitale**: dice a chi appartiene quella chiave
- I certificati sono emessi da un'autorità di certificazione all'interno di un'**infrastruttura a chiave pubblica** (PKI), da cui dipende la firma digitale

Firma digitale

Uno schema per verificare l'autenticità dei documenti digitali, basato sulla crittografia asimmetrica.

- Il firmatario usa la sua **chiave privata**; chiunque verifica con la sua **chiave pubblica**
- **Integrità**: garantisce che il documento non sia stato alterato dopo la firma (grazie all'impronta)
- **Autenticazione**: una firma valida dà al destinatario un motivo molto forte per credere che il documento sia stato creato dal titolare della chiave

Attenzione al lessico: la firma digitale non è l'immagine di una firma scansionata, ma un calcolo sull'impronta del documento, diverso per ogni documento. E nel diritto italiano "firma digitale" ha un significato più stretto: è un tipo di firma elettronica qualificata (art. 1, lett. s, CAD).

Alice firma un documento per Bob

Alice firma

Documento di Alice

Il sottoscritto Mario Rossi accetta la proposta del 3 novembre 2026.

1. Alice calcola l'impronta (SHA-256)

Impronta: `7a936f6a7f6d2ccd9b6567fbe0d77cb86abdf1a3b179a3a7eb6324644363819b`

2. Alice firma con la sua chiave privata

Firma: `b3b9be1e9bdc9b…2ca41a`

→

Bob verifica

Documento ricevuto da Bob

Il sottoscritto Mario Rossi accetta la proposta del 3 novembre 2026.

Chiave pubblica di Alice: `047178ef…0d44`

Modifica una parola in transito

3. Bob verifica con la chiave pubblica di Alice

✓ firma valida: documento integro, firmato da Alice

Se in transito «accetta» diventa «rifiuta»: **✕ firma non valida: documento alterato o firmatario diverso**

Se il documento viene alterato

Documento originale

impronta calcolata da Bob

`c7a1…09e4`

impronta firmata da Alice

`c7a1…09e4`

✓ **coincidono: firma valida**

Documento modificato

impronta calcolata da Bob

`5f3d…a812`

impronta firmata da Alice

`c7a1…09e4`

✕ **diverse: firma non valida**

La firma resta legata a **quel** documento: non si può "staccare" e incollare su un altro, né sopravvive a una modifica.

Certificato digitale

Un documento elettronico che attesta l'associazione univoca tra una chiave pubblica e l'identità di una persona.

Certificato digitale

Nome	Alice Rossi
Indirizzo	via Galliera 3, Bologna
Email	alice@studio-legale-esempio.it
Chiave pubblica	`04a9f2…7c1e`

Ma chi garantisce che il certificato dica il vero? Qualcuno di fidato deve firmarlo.

Infrastruttura a chiave pubblica (PKI) e X.509

- **X.509**: il formato più comune per i certificati digitali
- **PKI X.509** (RFC 5280): l'insieme di processi e mezzi con cui terze parti fidate verificano e garantiscono l'identità di un utente e le associano una chiave pubblica
- I certificati X.509 sono usati in molti protocolli Internet, tra cui **TLS**, alla base di **HTTPS**: il lucchetto nella barra del browser. Oggi si usa TLS 1.3 (RFC 9846, 2026); il vecchio SSL è obsoleto

Ogni volta che aprite il sito della vostra banca, il browser verifica un certificato X.509 senza che ve ne accorgiate.

Il certificato firmato dall'autorità di certificazione

Certificato di Alice

Nome: Alice Rossi
Email: alice@studio-legale-esempio.it
Chiave pubblica: `04a9f2…7c1e`
Valido dal 01/03/2026 al 01/03/2029

Firma della CA: `3045…b2`

Autorità di certificazione (CA)

Verifica l'identità di Alice (di persona, con lo SPID, con la CIE…), poi firma il certificato con la **propria** chiave privata.

Chi si fida della CA può fidarsi del certificato.

Dentro un certificato X.509

Campo	Cosa contiene	Esempio
Soggetto (*Subject*)	a chi appartiene la chiave	CN=Alice Rossi, O=Studio Legale Esempio
Emittente (*Issuer*)	la CA che lo ha firmato	CN=Esempio Qualified CA
Validità	dal… al…	01/03/2026 – 01/03/2029
Chiave pubblica	algoritmo e valore	EC P-256, `04a9f2…7c1e`
Usi consentiti	firma, cifratura, autenticazione	non ripudio
Firma	la firma della CA su tutti i campi	ECDSA con SHA-256

Nel browser: clic sul lucchetto accanto all'indirizzo, poi "Il certificato è valido" per vedere questi campi su un sito vero.

La catena di fiducia X.509

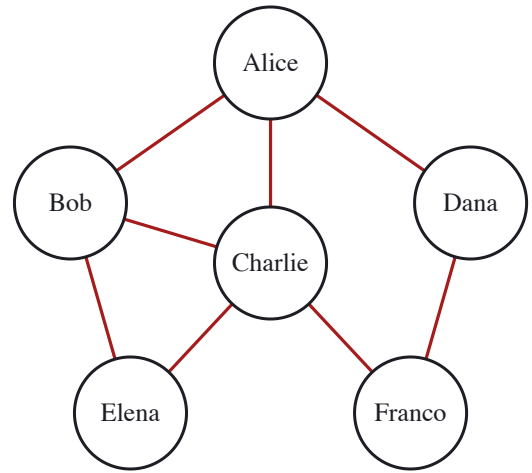
Le CA sono organizzate ad albero: la fiducia parte da poche autorità radice, già presenti nel browser o nel sistema operativo.



Un’alternativa: la rete di fiducia (PGP)

Nessuna autorità centrale: sono gli utenti a firmare i certificati gli uni degli altri.

- Alice si fida di Bob perché lo conosce di persona e ha firmato il suo certificato
- Se Bob ha firmato quello di Charlie, Alice può decidere di fidarsi di Charlie "per transitività"
- Usata soprattutto per la posta elettronica cifrata (standard OpenPGP, RFC 9580; programmi come GnuPG)



Provate voi: firmare e verificare

Lo strumento ufficiale della Commissione europea per firmare e verificare documenti secondo eIDAS (Digital Signature Service, DSS).

DSS demo: ec.europa.eu/digital-building-blocks/DSS/webapp-demo

- "Validate a signature": carica un file firmato (anche un .p7m o un PDF firmato) e leggi il rapporto di validazione. Funziona subito
- "Sign a document": firma un file in XAdES, CAdES, PAdES o JAdES; serve l'applicazione locale NexU con un lettore di smart card

I file caricati vengono trasmessi ai server della Commissione: per le prove usate documenti di esempio, mai atti riservati.

eIDAS: il regolamento europeo

electronic IDentification, Authentication and trust Services: Regolamento (UE) n. 910/2014.

- Base normativa comune per interazioni elettroniche sicure fra cittadini, imprese e pubbliche amministrazioni
- Interoperabilità in tutta l'Unione delle firme elettroniche, dei sigilli, delle validazioni temporali

> *"Le firme elettroniche qualificate basate su un certificato qualificato rilasciato in uno Stato membro [...] sono riconosciute [...] quali firme elettroniche qualificate [...] in tutti gli altri Stati membri."*

art. 24 bis, par. 1 (prima era l'art. 25, par. 3, soppresso da eIDAS 2)

Per il giurista

Il regolamento è stato profondamente modificato dal **Reg. (UE) 2024/1183** ("eIDAS 2"), in vigore dal 20 maggio 2024, che introduce il **portafoglio europeo di identità digitale** (EUDI Wallet).

eIDAS 2 e il portafoglio digitale

Ogni Stato membro deve offrire ai cittadini un portafoglio digitale (EUDI Wallet) per identificarsi, conservare documenti e firmare.

- Termine: **24 dicembre 2026**, 24 mesi dopo l'entrata in vigore degli atti di esecuzione (art. 5 bis, par. 1)
- Il portafoglio deve permettere a tutte le persone fisiche di **firmare con firma qualificata, gratuitamente** (gli Stati possono limitare la gratuità agli usi non professionali)
- In Italia: **Sistema IT-Wallet** (art. 64-quater CAD), con un portafoglio pubblico nell'app IO e portafogli privati accreditati da AgID

> ***Per il giurista***
>
> Oggi "Firma con IO" offre già una firma qualificata gratuita, ma solo per i documenti che un ente chiede di firmare: non è ancora la firma gratuita generalizzata voluta dal regolamento.
>
> ¶ art. 5 bis, par. 5, lett. g), eIDAS

eIDAS riconosce tre tipi di firma elettronica

1

Firma elettronica
semplice

2

Firma elettronica avanzata
FEA, AdES

3

Firma elettronica qualificata
FEQ, QES; in Italia la firma digitale ne è un tipo

Ogni livello aggiunge requisiti, e con essi valore probatorio.

1. Firma elettronica (semplice)

Il livello base: dati in forma elettronica, allegati o connessi ad altri dati, usati dal firmatario per firmare.

Il regolamento stabilisce un principio di non discriminazione:

> *"A una firma elettronica non possono essere negati gli effetti giuridici e l'ammissibilità come prova in procedimenti giudiziari per il solo motivo della sua forma elettronica o perché non soddisfa i requisiti per firme elettroniche qualificate."*

art. 25, par. 1, eIDAS

Esempi: il nome scritto in fondo a una email; il clic su "Accetto"; un codice PIN.

Per il giurista

In Italia il suo valore come forma scritta e come prova è **liberamente valutabile** dal giudice, secondo sicurezza, integrità e immodificabilità.

¶ art. 20, c. 1-bis, CAD

2. Firma elettronica avanzata (FEA)

Deve soddisfare quattro requisiti (art. 26 eIDAS):

1. è connessa **unicamente** al firmatario
2. è idonea a **identificare** il firmatario
3. è creata con dati che il firmatario può utilizzare, con un elevato livello di sicurezza, sotto il proprio **esclusivo controllo**
4. è collegata ai dati sottoscritti in modo da consentire l'**identificazione di ogni successiva modifica**

Esempi: firme in formato XAdES, CAdES, PAdES senza certificato qualificato o senza dispositivo qualificato; in Italia la **firma grafometrica** su tablet, se il sistema rispetta le regole tecniche.

> ***Per il giurista***
>
> Il requisito 4 non chiede un documento "a prova di manomissione" (così la slide del 2024) ma una modifica **rilevabile**: è esattamente ciò che fa l'impronta.
>
> La FEA "italiana" del d.P.C.M. 22 febbraio 2013 vale solo nei rapporti tra firmatario e chi la offre, per esempio la banca.
>
> ¶ artt. 56 e 60 d.P.C.M. 22/2/2013

I requisiti della FEA, uno per uno

1
connessa **unicamente** al firmatario

2
idonea a **identificarlo**

3
creata con dati sotto il suo **esclusivo controllo**

4
ogni successiva modifica è **rilevabile**

Requisito	Come lo realizza la crittografia
1 e 2	il certificato lega la chiave pubblica all’identità del firmatario
3	la chiave privata resta nel dispositivo del firmatario (o in un sistema protetto)
4	si firma l’impronta del documento: cambiare un bit invalida la firma

FEA: i formati

Quando un servizio pubblico online richiede una firma avanzata, deve accettarla almeno in questi formati.

- Per anni: Decisione di esecuzione (UE) **2015/1506** (formati XML, CMS, PDF)
- Ora: **Regolamento di esecuzione (UE) 2026/248**, che l'ha abrogata; il nuovo elenco si applica dal 23 febbraio 2027 e aggiunge **JAdES** (JSON) e i contenitori **ASiC**
- I formati sono specifiche tecniche **ETSI**:

XAdES	**CAdES**	**PAdES**
XML	CMS, il file .p7m	PDF

Correzione rispetto al 2024: questi atti non dicono quali formati una FEA "deve avere" (una FEA è tale per i requisiti dell'art. 26), ma quali formati la PA deve accettare.

ETSI

European Telecommunications Standards Institute: organizzazione europea di normazione riconosciuta dall'UE. Il suo comitato tecnico ESI scrive le norme per firme e servizi fiduciari a sostegno di eIDAS.

- Il regolamento dice **cosa** deve garantire una firma
- Le norme ETSI dicono **come**: formati dei file, profili dei certificati, requisiti per i prestatori di servizi fiduciari

È la stessa divisione del lavoro che c'è tra il codice civile e le regole tecniche: la norma fissa l'effetto, lo standard tecnico il modo.

XAdES: XML Advanced Electronic Signature

- Firma codificata in **XML**, un formato testuale leggibile sia dalle persone sia dai programmi
- Si può usare per qualsiasi tipo di dato: immagini, audio, PDF, file binari
- Tre modi di collegare firma e dati:
  - **interna** (*enveloped*): la firma è dentro il documento XML firmato
  - **avvolgente** (*enveloping*): i dati sono dentro la struttura XML della firma
  - **distaccata** (*detached*): firma e dati restano in file distinti
- **Vantaggio**: facilita l'elaborazione automatica e supporta la firma multipla, anche in parallelo o in sequenza

Correzione rispetto al 2024: le modalità sono tre, non due.

CAdES: CMS Advanced Electronic Signature

- **CMS** (*Cryptographic Message Syntax*): standard IETF per messaggi protetti da crittografia
- Si applica a **qualsiasi file**: il risultato è una "busta" che contiene documento e firma
- In Italia è il famoso file **.p7m** (dati dentro la busta) o **.p7s** (firma separata): per leggerlo serve un software che apre la busta e verifica la firma
- Supporta più firmatari: **firme parallele** e **controfirme**; per firmare più documenti insieme si usa un contenitore **ASiC-E**

Correzione rispetto al 2024: CAdES non è limitato ai "dati binari" e consente la firma di più soggetti.

Per il giurista

Nel processo civile telematico gli atti firmati digitalmente possono essere in CAdES o in PAdES: le Sezioni Unite li hanno ritenuti equivalenti.

¶ Cass., S.U., 27 aprile 2018, n. 10266

Nel processo amministrativo telematico è ammesso solo PAdES.

PAdES: PDF Advanced Electronic Signature

- Riservato ai file **PDF**: la firma è incorporata nel PDF stesso
- Il documento resta un normale PDF: si legge con qualsiasi lettore, e i lettori PDF (es. Adobe Acrobat Reader) mostrano e verificano la firma
- Supporta più firme **in sequenza**: ogni nuova firma copre il documento e le firme precedenti; non le firme in parallelo
- Ideale per documenti destinati a essere letti da persone; per dati da elaborare automaticamente si preferisce XAdES

Correzione rispetto al 2024: la verifica di una firma PAdES è automatica come per gli altri formati.

3. Firma elettronica qualificata (FEQ)

Una firma avanzata con due requisiti in più. Ha gli stessi effetti giuridici della firma autografa (art. 25, par. 2, eIDAS).

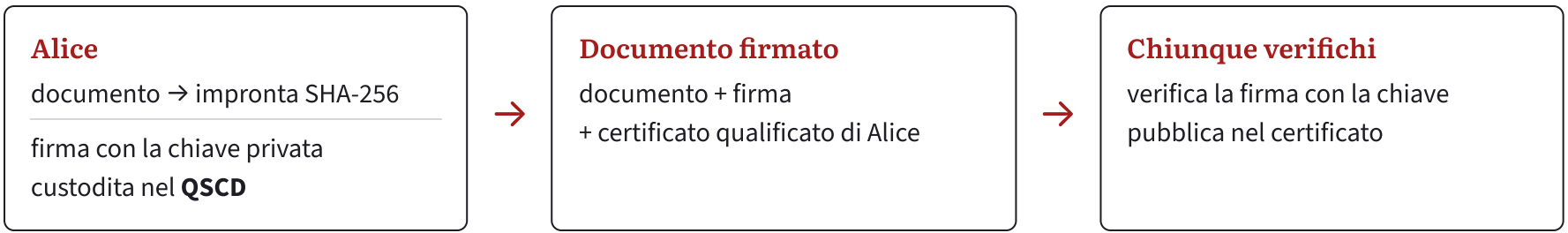
Il firmatario deve:

1. usare un **certificato qualificato**, rilasciato da un **prestatore di servizi fiduciari qualificato** (QTSP) dell'UE
2. usare un **dispositivo per la creazione di una firma qualificata** (QSCD)

Esempi: XAdES, PAdES, CAdES con certificato qualificato e dispositivo sicuro: smart card, token USB, oppure **firma remota**: il dispositivo qualificato è un sistema protetto (HSM) presso il prestatore, e la password monouso sullo smartphone serve solo ad autorizzare la firma (art. 29 bis eIDAS).

> ***Per il giurista***
>
> In Italia la **firma digitale** è un tipo particolare di firma qualificata, basata su chiavi pubblica e privata (art. 1, lett. s, CAD).
>
> I prestatori qualificati sono nell'elenco di fiducia europeo (EU Trusted List).

La firma qualificata, in figura



Prestatore di servizi fiduciari qualificato (QTSP): ha identificato Alice e firmato il suo certificato qualificato; è vigilato (in Italia dall'AgID) e iscritto nell'elenco di fiducia.

Le firme nel diritto italiano

Firma	Forma scritta ed efficacia probatoria
Semplice	liberamente valutabili dal giudice (sicurezza, integrità, immodificabilità)
Avanzata	forma scritta ed efficacia dell'**art. 2702 c.c.** (scrittura privata)
Qualificata / digitale	come sopra; l'uso del dispositivo **si presume** riconducibile al titolare, salvo prova contraria; con certificato scaduto, revocato o sospeso equivale a **mancata sottoscrizione**

Per alcuni atti la legge pretende di più: le scritture dell'art. 1350, nn. 1–12, c.c. (es. trasferimento di immobili), se informatiche, richiedono a pena di nullità la **firma qualificata o digitale**.

Per il giurista

- ¶ art. 20, c. 1-bis e 1-ter, CAD
- ¶ art. 21, c. 2-bis, CAD
- ¶ art. 24, c. 4-bis, CAD
- ¶ artt. 1350, 2702 c.c.

Che firma è?

	Semplice	Avanzata	Qualificata
Scrivo «Avv. Mario Rossi» in fondo a una email Dati elettronici usati per firmare, ma senza i requisiti dell'art. 26 eIDAS.	✓		
Clicco «Accetto» sulle condizioni di un sito Manifesta una volontà, ma non identifica in modo affidabile chi ha cliccato.	✓		
Firmo su un tablet in banca, con la penna elettronica La firma grafometrica è una FEA se il sistema rispetta le regole tecniche (art. 56 d.P.C.M. 22/2/2013); vale nei rapporti con la banca.		✓	
Firmo un atto con la smart card e ottengo un file .p7m Firma digitale: certificato qualificato e dispositivo sicuro (la smart card).			✓
Firmo da remoto con un codice OTP inviato sul telefono dal prestatore qualificato Firma remota: la chiave è custodita in un dispositivo qualificato del prestatore.			✓
Incollo nel PDF l'immagine scansionata della mia firma Un'immagine si copia e si incolla: nessun legame con il contenuto del documento.	✓		

Password monouso e verifica in due passaggi

Un'autenticazione forte combina almeno due fattori di categorie diverse.

- **Qualcosa che conosci**: una password, un PIN
- **Qualcosa che hai**: lo smartphone, un token della banca
- **Qualcosa che sei**: l'impronta digitale, il volto

La combinazione più comune è la **verifica in due passaggi**: una password personale più un codice monouso generato o ricevuto sullo smartphone.

Per il giurista

È l'"autenticazione forte del cliente": due o più elementi di conoscenza, possesso e inerenza, **indipendenti** tra loro. Obbligatoria per accedere al conto online e per i pagamenti elettronici.

¶ artt. 4, n. 30, e 97, dir. (UE) 2015/2366 (PSD2)

Anche lo SPID di livello 2 chiede password più un secondo fattore.

Verifica in due passaggi: il codice che cambia

Telefono e server condividono un segreto; da quel segreto e dall'ora corrente calcolano lo stesso codice di 6 cifre, che cambia ogni 30 secondi.

Segreto condiviso, scambiato una sola volta con il QR code: `KRSX G5CT MVRX EZLU KRSX G5CT MVRX EZLU`

Il tuo telefono

499 669

nuovo codice tra 30 s

`codice = HMAC-SHA1(segreto, ora ÷ 30 s)`
ridotto a 6 cifre (RFC 6238)
intervallo n. 59.824.560

Il server della banca

499 669

✓ **i due codici coincidono, senza che nessuno li trasmetta**

Il telefono invia 499 669: ✓ **codice accettato**

Codice di un minuto fa, 965 546: ✕ **codice scaduto**

Standard TOTP (RFC 6238), basato su HOTP (RFC 4226): non è una sfida-risposta, la "sfida" è l'ora corrente.

Password monouso: sfida e risposta (*challenge-response*)

1. Alice dichiara di voler accedere al Servizio
2. Il Servizio sceglie una **sfida** e la invia ad Alice
3. Alice calcola una **risposta** alla sfida e la rimanda indietro
4. Il Servizio confronta la risposta ricevuta con quella attesa: se corrispondono, accesso consentito

"Monouso" perché la risposta vale solo per quella sfida, e la sfida cambia ogni volta: registrare una risposta non serve a nulla.

Sfida e risposta con crittografia simmetrica

Alice e il Servizio condividono una chiave segreta K. Alice risponde cifrando la sfida con K; il Servizio decifra e confronta.

Prima: Alice e il Servizio condividono una **chiave segreta K**.

Alice	Servizio
1 Alice dichiara di voler accedere → «sono Alice»	
	2 Il Servizio invia una sfida casuale ← sfida: `1dd9538e9d105974`
3 Alice cifra la sfida con la chiave segreta condivisa K → sfida cifrata: `b1215e3e5633…5dbfdd`	
	4 Il Servizio decifra con K e confronta con la sfida ✓ **accesso consentito**

Il limite: anche il Servizio custodisce K; se gliela rubano, l'attaccante può fingersi Alice.

Sfida e risposta con crittografia asimmetrica

Alice ha registrato la sua chiave pubblica presso il Servizio; risponde firmando la sfida con la chiave privata, che non lascia mai il suo dispositivo.

Prima: Alice ha registrato presso il Servizio la sua **chiave pubblica**; la privata resta sul suo dispositivo.

Alice	Servizio
1 Alice dichiara di voler accedere → «sono Alice»	
	2 Il Servizio invia una sfida casuale ← sfida: `5ca96d0634c655d0`
3 Alice firma la sfida con la sua chiave privata → firma: `b7ea67b6778c…331342`	
	4 Il Servizio verifica la firma con la chiave pubblica di Alice ✓ **accesso consentito**

È il principio delle passkey (FIDO2/WebAuthn): niente segreti condivisi da rubare.

È il meccanismo delle passkey: standard W3C Web Authentication Level 3, Raccomandazione del 25 agosto 2026.

Verifica rapida

Un contratto di compravendita di un immobile, stipulato come documento informatico, quale firma richiede a pena di nullità?

- A Basta una firma semplice
- B Una firma avanzata
- **C Una firma qualificata o digitale** ✓ giusta

Per le scritture dell'art. 1350, nn. 1–12, c.c. l'art. 21, c. 2-bis, CAD richiede la firma qualificata o digitale (salvo sottoscrizione autenticata).

Perché un codice OTP rubato ieri non permette di entrare oggi?

- A Perché è cifrato
- **B Perché dipende dall'ora o da una sfida che nel frattempo è cambiata** ✓ giusta
- C Perché la banca lo cancella

Il codice è calcolato dall'ora corrente (TOTP) o da una sfida nuova: vale una sola volta e per poco tempo.

Capo VIII

VIII | Marcatura temporale fidata

Dimostrare che un documento esisteva a una certa data

Marca temporale (*timestamp*)

Data e ora in forma di caratteri: per il giurista un **riferimento temporale**, che diventa **validazione temporale** quando un terzo lo lega in modo verificabile a certi dati.

Tempo coordinato universale (UTC), formato ISO 8601	`2026-11-15T10:00:00Z`
Ora italiana (Europe/Rome), con lo scarto da UTC	`2026-11-15T11:00:00+01:00`
Tempo Unix: secondi trascorsi dal 1° gennaio 1970, 00:00 UTC	`1794736800`

Da tempo Unix a data

`1602086059` [Esempio: 1602086059]

UTC `2020-10-07T15:54:19Z`
in Italia `2020-10-07T17:54:19+02:00`

Da data e ora italiane a tempo Unix

`15/11/2026, 11:00:00` [Adesso]

Unix `1794736800`
UTC `2026-11-15T10:00:00Z`

Marcatura temporale con infrastruttura a chiave pubblica

Un'autorità di marcatura temporale (TSA, *Time Stamping Authority*) attesta, con la propria firma, che un'impronta esisteva in un certo istante.

- Prova che quei dati **esistevano** in quel momento e che **non sono cambiati** dopo; non prova chi ne è l'autore
- Lo standard **RFC 3161** definisce il protocollo, basato su una PKI X.509
- La TSA riceve **solo l'impronta** del documento, vi associa data, ora e numero di serie e firma il tutto: **non vede mai il documento**
- Nel diritto UE la TSA è un **prestatore di servizi fiduciari qualificato** (non più "certificatore accreditato", termine precedente a eIDAS)

Per il giurista

Una validazione temporale elettronica **qualificata** gode della presunzione di accuratezza della data e dell'ora e di integrità dei dati cui si riferisce.

¶ art. 41, par. 2, Reg. (UE) 910/2014 (eIDAS)

Per il documento informatico: "la data e l'ora di formazione [...] sono opponibili ai terzi se apposte in conformità alle Linee guida".

¶ art. 20, c. 1-bis, CAD; art. 2704 c.c. (data certa)

La marcatura temporale, passo per passo

1 Lo studio calcola l'impronta del documento

Parere legale sul contratto di fornitura Rossi–Bianchi, versione definitiva.

Impronta SHA-256: `e99697b0589c6177274b17102f72de7a800d56ce3a66d85a214a1007883b4154`

2 Invia alla TSA solo l'impronta: il documento resta nello studio

`e99697…4154`



3 La TSA aggiunge data e ora e firma impronta + data/ora

Impronta	`e99697b058…3b4154`
Data e ora	`2026-11-15T10:00:00Z`
Numero di serie	`2026-004817`
Firma della TSA	`e46f16a4c3…99effd`

4 Chiunque può verificarla con il certificato della TSA

✓ marca temporale valida: questo documento esisteva già il 2026-11-15T10:00:00Z

Il pacchetto finale

Chi riceve il documento può verificare, anche dopo anni, chi l'ha firmato e da quando esisteva.

Documento
il file originale

Firma di Alice
sull'impronta del documento

Certificato di Alice
firmato da una CA

Marca temporale
impronta + data e ora

Firma della TSA
sulla marca temporale

Certificato della TSA
firmato da un'altra CA

Lo standard ANSI ASC X9.95

Oltre all'RFC 3161 esistono altri standard (ANSI X9.95 per il settore finanziario, ISO/IEC 18014) e altre famiglie di schemi.

- **Basati su firma** (PKI): quello visto finora
- **Collegati** (*linked*): ogni marca è collegata alle precedenti, per esempio con un albero di Merkle (Haber e Stornetta, 1991)
- **Chiave transitoria** (*transient-key*): variante PKI con chiavi di firma di breve durata
- **MAC**: schema semplice basato su una chiave segreta condivisa
- **Database**: le impronte dei documenti sono conservate in un archivio fidato
- **Distribuiti**: le impronte sono registrate su una blockchain (prossima slide)

Correzione rispetto al 2024: l'elenco non è "il contenuto di X9.95" (norma a pagamento, non verificabile) ma una classificazione generale degli schemi.

Marcatura temporale distribuita

Invece di un'unica TSA, ci si affida a molti nodi che si accordano tra loro (consenso). L'impronta del documento viene inserita in una transazione registrata sulla blockchain.

- Si registra **solo l'impronta**: l'inclusione in un blocco prova che il dato esisteva **non più tardi** di quel blocco
- L'immutabilità è probabilistica: cresce con il numero di blocchi successivi (le "conferme")
- Strumento gratuito: **OpenTimestamps** calcola l'impronta nel browser e la ancora nella blockchain di Bitcoin

Per il giurista

La memorizzazione su registri distribuiti "produce gli effetti giuridici della validazione temporale elettronica di cui all'articolo 41" eIDAS: quella semplice, non la qualificata.

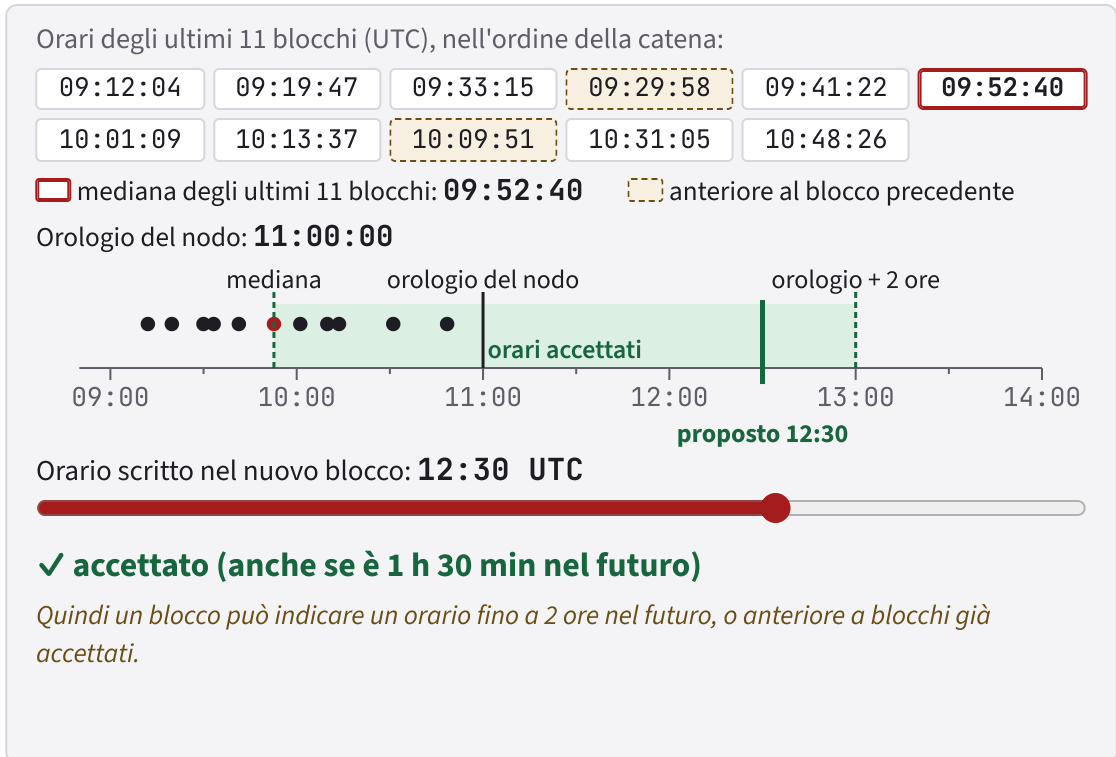
¶ art. 8-ter, c. 3, d.l. 135/2018 (gli standard AgID del c. 4 non risultano pubblicati)

eIDAS 2 introduce i **registri elettronici qualificati**: presunzione di ordine cronologico e di integrità delle registrazioni.

¶ artt. 45 duodecies e 45 terdecies eIDAS; Reg. es. (UE) 2025/2531

Marcatura temporale distribuita: i problemi

- La sicurezza dipende dal **consenso**: in Bitcoin è il **proof of work**, un enorme lavoro di calcolo per ogni nuovo blocco (il puzzle del Capo V)
- Riscrivere blocchi già confermati richiede la maggioranza della potenza di calcolo della rete
- Ma l'orario scritto nel blocco lo sceglie chi lo crea, entro certi limiti: è **approssimativo**, fino a 2 ore nel futuro, e può essere anteriore a blocchi già accettati
- Vale per Bitcoin e catene simili; in Ethereum l'ora è fissata dallo slot (12 secondi)



Verifica rapida

Per ottenere una marca temporale su un parere riservato, cosa invia lo studio alla TSA?

A Il parere in PDF

B Solo l’impronta del parere ✓ giusta

C Il parere cifrato con la chiave pubblica della TSA

La TSA riceve e firma solo l’impronta con la data e l’ora: il contenuto del parere resta nello studio.

L’orario scritto in un blocco Bitcoin è preciso al secondo?

A Sì, è garantito dal consenso

B No: può scostarsi anche di un paio d’ore ✓ giusta

C Dipende dal fuso orario del notaio

Le regole del protocollo accettano un blocco se il suo orario è successivo alla mediana degli 11 blocchi precedenti e non oltre 2 ore nel futuro.

Capo IX

IX

Identità decentralizzate

Quando la chiave pubblica diventa un nome

Le chiavi come identità

Mirko Zichichi *associato a* `0x7c3f9a1e…b42d`

indirizzo pubblico (alfanumerico)

Su una blockchain non ci si registra con nome e cognome: si è identificati da un indirizzo derivato da una chiave pubblica.

Come si crea una nuova identità

Basta generare una nuova coppia di chiavi asimmetriche (sk, pk).

- La chiave pubblica **pk** è il "nome" dell'identità
  - è uno **pseudonimo**
  - in pratica si usa spesso l'**impronta di pk** come indirizzo (*address*): in Bitcoin, nel formato classico, RIPEMD-160(SHA-256(pk))
- La chiave privata **sk** permette di "parlare a nome" dell'identità: di firmare
- Ognuno controlla la propria identità perché solo lui conosce sk
- Se pk "sembra casuale", nessuno sa associarla a una persona… finché non lo rivela un suo comportamento o un collegamento esterno

Gestione decentralizzata delle identità

Crea una nuova identità *Nessun registro centrale: chiunque può crearne quante vuole.* 3 create

	Indirizzo (impronta della chiave pubblica)	**Chiave pubblica**	**Chiave privata**
◉	`0xc4964aa0f50ad9d477b9eded0cc0c88fa2de351a`	`04b8a36b…4053b2`	Mostra la chiave privata (nella realtà, mai!)
○	`0x7a1769793d2b7c504b2034cb0f4c236ffa1474be`	`040cd82b…ef19ae`	Mostra la chiave privata (nella realtà, mai!)
○	`0x0111a0da14e70567c3366998499789d25422e246`	`042f1068…7d3f77`	Mostra la chiave privata (nella realtà, mai!)

Messaggio

Dichiaro di essere il titolare di questo indirizzo.

Firma un messaggio con l'identità selezionata

Firma: `8ab4458e500c…affc83` **✓ firma valida: il messaggio viene da chi controlla 0xc4964a…351a**

Gestione decentralizzata: le conseguenze

- Chiunque può creare una nuova identità in qualsiasi momento, e quante ne vuole
- La probabilità di generare la stessa chiave di un altro utente è trascurabile, purché la chiave sia generata con una buona fonte di casualità (nel 2013 un difetto del generatore casuale di Android espose al furto i portafogli Bitcoin creati su Android)
- Nessun punto centrale di coordinamento, nessuna autorità che registri le identità
- In Bitcoin queste identità si chiamano **indirizzi**

Per il giurista

Pseudonimo non vuol dire anonimo. I dati pseudonimizzati restano dati personali per chi può ricondurli a una persona.

¶ art. 4, n. 5, e considerando 26 GDPR

¶ Corte di giustizia UE, C-413/23 P, GEPD c. SRB (2025): conta la prospettiva di chi tratta i dati

Identificatori decentralizzati (DID)

Un nuovo tipo di identificatore che permette un'identità digitale verificabile e decentralizzata. Sono spesso il mattone delle architetture di identità auto-sovrana (*self-sovereign identity*), anche se lo standard non usa questo termine.

- Un DID identifica qualsiasi soggetto: una persona, un'organizzazione, una cosa, un modello di dati
- Chi controlla un DID può dimostrarlo crittograficamente (con la sua chiave privata)
- Può essere svincolato da registri centralizzati, fornitori di identità e autorità di certificazione; non serve nemmeno una blockchain (metodi `did:web`, `did:key`). Esempio: `did:example:123456789abcdefghi`

Per il giurista

Standard W3C: *Decentralized Identifiers (DIDs) v1.0*, Raccomandazione del 19 luglio 2022; la v1.1 è in fase di Candidate Recommendation (marzo 2026).

Il portafoglio europeo di identità digitale (EUDI Wallet) **non usa i DID**: i dati di identità sono emessi nei formati SD-JWT VC e ISO mdoc.

¶ Reg. es. (UE) 2024/2977, modificato dal Reg. es. (UE) 2026/1731

Il documento DID

```
{
  "@context": "https://www.w3.org/ns/did/v1",
  "id": "did:example:123456789abcdefghi",
  "verificationMethod": [{
    "id": "did:example:123456789abcdefghi#chiave-1",
    "type": "Multikey",
    "controller": "did:example:123456789abcdefghi",
    "publicKeyMultibase": "z6MkmM42vxfqZQsv4ehtTjFF…"
  }],
  "authentication": ["#chiave-1"],
  "service": [{
    "id": "#sito",
    "type": "LinkedDomains",
    "serviceEndpoint": "https://studio-legale-esempio.it"
  }]
}
```

Schema: w3.org/TR/did-core

Gli elementi principali:

1. **id**: il DID stesso
2. **verificationMethod**: le chiavi pubbliche
3. **authentication**: quali chiavi servono per autenticarsi
4. **service**: dove contattare il soggetto

Correzione rispetto al 2024: data e firma non fanno parte del documento DID nello standard v1.0; le date sono metadati restituiti da chi lo risolve.

Verifica rapida

Un indirizzo Bitcoin non contiene nome e cognome. I dati delle sue transazioni sono dati personali?

A No, sono anonimi

B Possono esserlo: sono pseudonimi, riconducibili a una persona con informazioni ulteriori — **✓ giusta**

C Solo se l'importo supera 1.000 €

> Pseudonimo non è anonimo: se il titolare può essere identificato con mezzi ragionevolmente utilizzabili, si applica il GDPR.

Chi rilascia un DID?

A Il Comune di residenza

B Un'autorità di certificazione europea

C Lo crea il titolare stesso, generando una coppia di chiavi — **✓ giusta**

> Nessuna autorità centrale: il controllo del DID deriva dal possesso della chiave privata.

Grazie!

Domande?

Mirko Zichichi · mirko.zichichi@iota.org · mirkozichichi.me

Le slide interattive:
mirkozichichi.me/slides/sicurezzagiur2026

A

Allegato A

Appendice

Per approfondire: norme, standard, strumenti e un glossario

Per approfondire: sicurezza e crittografia (Capi I–IV)

- **NIST CSRC Glossary**: definizioni ufficiali di riservatezza, integrità, disponibilità, non ripudio, con la fonte di ciascuna. csrc.nist.gov/glossary
- **B. Schneier, *Secrets and Lies*, prefazione**: perché la sicurezza è un processo, non un prodotto. schneier.com/books/secrets-and-lies-pref
- **C. Mc Mahon, *In Defence of the Human Factor*** (2020): critica del luogo comune "l'utente è l'anello debole". pmc.ncbi.nlm.nih.gov/articles/PMC7365867
- **A. Kerckhoffs, *La cryptographie militaire*** (1883), il testo originale. petitcolas.net/kerckhoffs
- **NIST SP 800-63B-4** (2025): le regole attuali su password e autenticazione a più fattori. doi.org/10.6028/NIST.SP.800-63b-4
- **Menezes, van Oorschot, Vanstone, *Handbook of Applied Cryptography***, cap. 1, gratuito. cacr.uwaterloo.ca/hac
- **NIST IR 8547** (ottobre 2026): il calendario per abbandonare RSA e curve ellittiche. doi.org/10.6028/NIST.IR.8547
- **UE, tabella di marcia per la crittografia post-quantistica** (2025). digital-strategy.ec.europa.eu
- **Provare un cifrario**: CyberChef e cryptii.com

Per approfondire: hash e strutture dati (Capi V–VI)

- **A. Narayanan et al., *Bitcoin and Cryptocurrency Technologies*** (2016), cap. 1: hash, occultamento, puzzle, alberi di Merkle, identità. bitcoinbook.cs.princeton.edu
- **ACN, Linee guida funzioni crittografiche**: funzioni di hash e conservazione delle password, in italiano. acn.gov.it
- **NIST FIPS 180-4 (SHA-2) e FIPS 202 (SHA-3)**: gli standard delle funzioni hash raccomandate. csrc.nist.gov/pubs/fips/180-4/upd1/final
- **SHAttered** (2017): due PDF diversi con la stessa impronta SHA-1. shattered.io
- **NIST ritira SHA-1** (dicembre 2022): come e quando un algoritmo viene dismesso. nist.gov
- **Codice di procedura penale**, artt. 247, 254-bis e 260 (copia forense dei dati). normattiva.it
- **EDPB, Linee guida 02/2025 su blockchain e dati personali** (v2.0, luglio 2026). edpb.europa.eu

Per approfondire: firme elettroniche (Capo VII)

- **Regolamento eIDAS**, testo consolidato in italiano. eur-lex.europa.eu
- **Reg. (UE) 2024/1183 (eIDAS 2)** e portafoglio europeo di identità digitale. eur-lex.europa.eu
- **Reg. di esecuzione (UE) 2026/248**: i formati di firma avanzata che la PA deve accettare. eur-lex.europa.eu
- **CAD**, art. 20 (valore probatorio) e art. 21 (forma e firme). normattiva.it
- **AgID, IT-Wallet**: base normativa e linee guida. agid.gov.it/it/piattaforme/it-wallet
- **Garante privacy, provvedimento sulla biometria** (2014), anche sulla firma grafometrica. garanteprivacy.it
- **Commissione UE, DSS**: firmare e validare firme eIDAS. ec.europa.eu/digital-building-blocks/DSS/webapp-demo
- **Passkey**: W3C Web Authentication Level 3 e FIDO Alliance. w3.org/TR/webauthn-3, fidoalliance.org/passkeys

Per approfondire: tempo e identità (Capi VIII–IX)

- **IETF RFC 3161, *Time-Stamp Protocol***: la TSA riceve solo l'impronta. rfc-editor.org/rfc/rfc3161
- **Art. 8-ter d.l. 135/2018**: registri distribuiti, smart contract e validazione temporale. normattiva.it
- **eIDAS 2**: validazione temporale (artt. 41–42) e registri elettronici qualificati (artt. 45 duodecies e 45 terdecies). eur-lex.europa.eu
- **OpenTimestamps**: una marca temporale su Bitcoin, gratis, dal browser. opentimestamps.org
- **Corte di giustizia UE, C-413/23 P, GEPD c. SRB** (2025): quando i dati pseudonimizzati sono personali. eur-lex.europa.eu
- **W3C, *Decentralized Identifiers (DIDs) v1.0***. w3.org/TR/did-core
- **EUDI Wallet, Architecture and Reference Framework**: formati e protocolli del portafoglio europeo. eudi.dev

Le notizie citate in apertura

- **Rapporto Clusit 2026**, presentazione del 17 marzo 2026. securitysummit.it
- **ACN, Relazione annuale 2025** (sintesi). puntosicuro.it
- **Frigoriferi dei supermercati**, Il Post, 3 novembre 2026. ilpost.it
- **Una settimana di attacchi hacker e allarmi bomba**, Il Post, 9 novembre 2026. ilpost.it
- **Presunti file della DIA**, AGI, 9 novembre 2026. agi.it
- **Caso Paragon**, Internazionale, 12 marzo 2026. internazionale.it
- **La voce clonata del ministro Crosetto**, Il Post, 11 febbraio 2025. ilpost.it
- **Record di fattorizzazione RSA-260**, Cognition, 9 settembre 2026. cognition.com
- **Normativa**: l. 90/2024, d.lgs. 138/2024 (NIS2), Cyber Resilience Act

Glossario (1/4)

Termine	In inglese	In breve
Riservatezza	*confidentiality*	solo chi è autorizzato accede ai dati
Integrità	*integrity*	i dati non sono modificati senza autorizzazione
Disponibilità	*availability*	dati e servizi sono accessibili quando servono
Autenticazione	*authentication*	verificare l'identità di chi comunica
Non ripudio	*non-repudiation*	l'autore non può negare in seguito un'azione
Testo in chiaro / cifrato	*plaintext / ciphertext*	il messaggio prima e dopo la cifratura
Crittografia simmetrica	*secret-key cryptography*	la stessa chiave cifra e decifra
Crittografia asimmetrica	*public-key cryptography*	chiave pubblica e chiave privata, diverse e collegate
Attacco a forza bruta	*brute-force attack*	provare tutte le chiavi o password possibili
Attacco a dizionario	*dictionary attack*	provare prima le password più comuni

Glossario (2/4)

Termine	In inglese	In breve
Impronta	*hash, digest*	valore di lunghezza fissa calcolato da un dato
Collisione	*collision*	due dati diversi con la stessa impronta
Nonce	*nonce*	numero casuale usato una sola volta
Impegno	*commitment*	vincolarsi a un valore senza rivelarlo subito
Puntatore hash	*hash pointer*	riferimento a un dato insieme alla sua impronta
Albero di Merkle	*Merkle tree*	albero di impronte riassunto da un'unica radice
Firma digitale	*digital signature*	impronta cifrata con la chiave privata del firmatario

Glossario (3/4)

Termine	In inglese	In breve
Certificato	*certificate*	documento che lega una chiave pubblica a un'identità
Autorità di certificazione	*certification authority (CA)*	soggetto fidato che firma i certificati
Prestatore di servizi fiduciari qualificato	*qualified trust service provider (QTSP)*	soggetto vigilato che rilascia certificati qualificati, marche temporali e altri servizi eIDAS
Dispositivo per la firma qualificata	*QSCD*	smart card, token o sistema remoto certificato che custodisce la chiave privata
Infrastruttura a chiave pubblica	*PKI*	regole, autorità e sistemi che gestiscono i certificati
Marca temporale	*time stamp*	attestazione firmata di data e ora di un'impronta
Autorità di marcatura temporale	*time stamping authority (TSA)*	soggetto che rilascia le marche temporali

Glossario (4/4)

Termine	In inglese	In breve
Registro distribuito	*distributed ledger (DLT)*	registro replicato tra molti nodi che si accordano tra loro
Identificatore decentralizzato	*decentralized identifier (DID)*	identificatore controllato dal titolare tramite chiavi
Autenticazione a più fattori	*multi-factor authentication (MFA)*	almeno due tra: qualcosa che sai, che hai, che sei
Password monouso	*one-time password (OTP)*	codice valido una sola volta o per pochi secondi
Passkey	*passkey (FIDO2/WebAuthn)*	accesso senza password basato su una coppia di chiavi
Phishing	*phishing*	messaggio ingannevole per carpire credenziali o denaro
Ransomware	*ransomware*	software che cifra i dati della vittima e chiede un riscatto
Attacco DDoS	*distributed denial of service*	sommergere un servizio di richieste per renderlo irraggiungibile

Crediti

- **Immagini**: cilindro di Jefferson, foto NSA, pubblico dominio; Enigma al Museo Nazionale della Scienza e della Tecnologia "Leonardo da Vinci" di Milano, foto di Alessandro Nassiri, CC BY-SA 4.0; ritratto di Auguste Kerckhoffs, pubblico dominio (tutte da Wikimedia Commons)
- **Contenuti**: slide in collaborazione con prof. Stefano Ferretti; edizione interattiva aggiornata a novembre 2026
- **Le dimostrazioni** girano interamente nel browser: nessun dato inserito viene inviato a terzi



Versione interattiva delle slide:
mirkozichichi.me/slides/sicurezzagiur2026